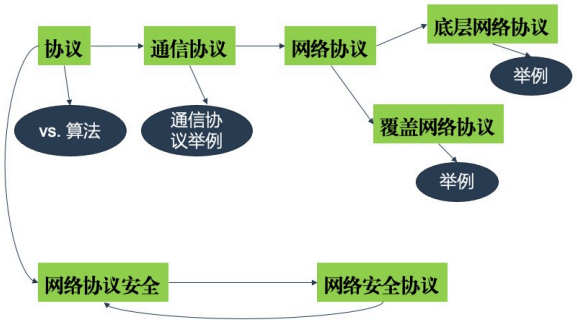
网络协议安全 与 网络安全协议

PPT版权：徐恪（清华计算机系）、李琦（清华网研院）



什么是通信协议（communication protocol）？

拉丁语protocollum：

来自希腊语 protokollon。protos为“第一的、最初的”，kolla为“胶水”。意思是一张粘在官方文件或手稿首页的羊皮纸，记录了该文件的基本信息，如日期、作者、摘要等。

20世纪初，引申为：

一套官方的格式、礼仪和程序规则。

20世纪60年代，用于计算机通信，表示：

通信实体之间为交换信息而建立的一套规则。

包括：

①用什么样的符号 = 语法

②代表的含义，期望的响应 = 语义

③顺序和时间要求 = 时序

以及规则、错误处理方法等

密码协议（cryptographic protocol）

使用密码学方法以实现安全相关功能的协议。

涉及空间或时间的多方之间的数据交换。

可以是抽象的或者具体的。

密码协议 vs 网络协议

密码协议可以实现为网络协议，也可以网络不相关的

密码协议基于密码原语序列，状态迁移通常基于大量的计算

网络协议基于网络原语序列，状态迁移规则通常较为简单

例：

TLS既是密码协议，也是网络协议

RSA签名是密码协议

雨课堂 Rain Classroom

简单协议 vs. 复杂协议

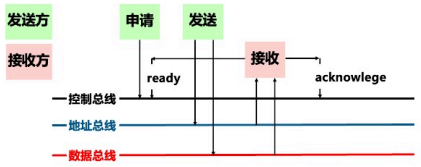
分离事务通信 (split-transaction)的总线通信协议：

控制线：双向

数据线：

地址线：

代码量：100s



零知识证明协议：

若干轮交互或大量的数据传输

大量的计算

代码量大而且复杂（>10000）

协议 vs. 算法

相似：

明确的步骤

输入-输出的关系

都通过计算部件实现

不同：

协议：多个实体之间的交互逻辑

通常在开放的、不确定的、并发的、甚至对抗性的分布式环境中运行。

算法：单个实体内部的计算逻辑

通常在一个可控的、封闭的上下文中运行。

局域网协议、广域网协议等底层网络协议

局域网：以太网协议

广域网：PPP、HDLC协议等

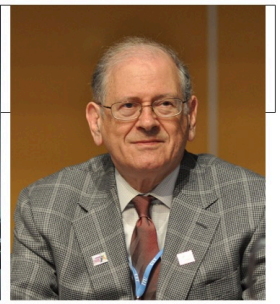
工控网/物联网：Modbus、IEC61850等

网际互联协议、覆盖网络协议

IP

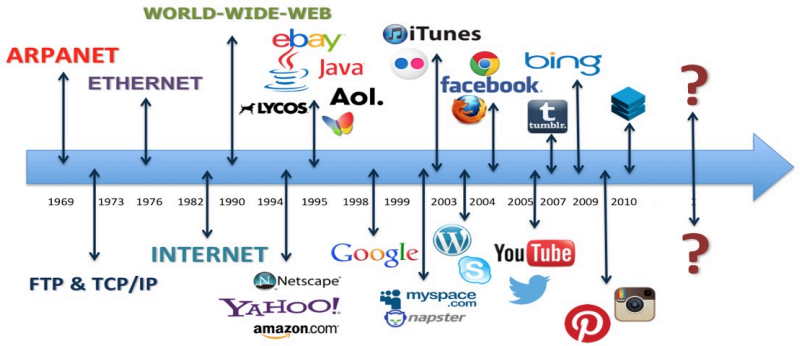
TCP

Tor



上世纪70年代，罗伯特·卡恩和文顿·瑟夫开发了TCP/IP协议。TCP/IP协议是互联网的核心，它采纳的征求修正意见书（RFC）过程，一直是发展互联网协议与标准所使用的机制，至今仍然发挥着作用

TCP/IP协议（Internet协议）



因特网的前身为ARPNET，最初DARPA资助开发，目前已发展成为全球最大的基础设施

网络协议安全与网络安全协议

网络协议安全：风险在哪里？ —对策→ 网络安全协议：机制有什么？

网络安全协议：机制有什么？ —风险分析→ 网络协议安全：风险在哪里？

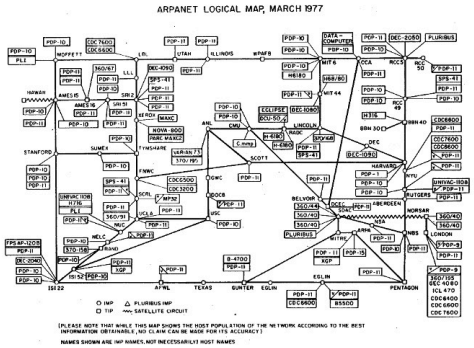
机密性
完整性
可用性
认证
……

TLS
密钥交换
记录协议
IPSec
AH
ESP
……

密码协议
与
密码原语

TCP/IP协议栈安全

互联网在设计之初仅面向可信的、少量的用户群体，因此并未考虑安全性的问题。但随着互联网的发展，网络的安全问题变得逐渐突出



单选题 1分

密码学较少地用于保障

A 机密性

B 完整性

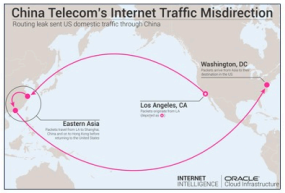
C 非否认性/认证

D 可用性

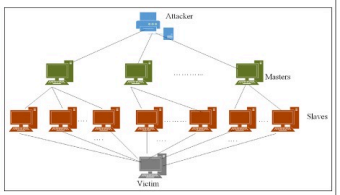
雨课堂 Rain Classroom

网络安全事件频发

2013年6月5日，前美国中央情报局雇员斯诺登向英国《卫报》和美国《华盛顿邮报》爆料，曝光了美国国家安全局（NSA）等美国政府部门监视公民隐私的“棱镜（PRISM）”计划



2008年，巴基斯坦电信局工程师误配置BGP路由信息，向全球送出广播，宣称自己才是全球YouTube互联网地址的合法目的地，导致YouTube断网2小时



2016年10月21日，美国域名服务商Dyn遭到DDoS攻击，导致该服务商的多家客户网站域名不能访问，包括twitter，Paypal，Spotify等知名公司

主要内容

机密性

协议栈	网络攻击	攻击共性特征	协议栈的缺陷	防御
链路层	• 帧嗅探 • ARP污染	①攻击者进行身份欺骗，伪装成原通信会话的合法参与方	①网络地址可伪造 ②系统随机化程度不够	①真实地址与真实身份 ②网络系统随机化
网络层	• IP地址欺骗 • IPID误用 • IP分片误用 • ICMP误用 • 路由劫持	②攻击者伪造请求，并观测、判断目标对请求的响应，推理出受害通信会话的状态信息 ③攻击者依据推理出的会话状态信息，伪造可被原会话接受的数据包，注入原合法数据流中，进行恶意攻击		
传输层	• TCP劫持 • TCP DoS			

完整性

可用性

主要内容

第一节：TCP/IP协议工作原理
(1) 协议栈中消息的纵向传递
(2) 协议栈中消息的横向安全

第二节：链路层安全
(1) ARP欺骗与污染
(2) 网络监听与嗅探

第三节：网络层安全
(1) 源地址假冒攻击
(2) IP分片攻击原理
(3) IPSec协议
(4) 网络入侵检测系统IDS
(5) 域内路由安全
(6) 域间路由安全

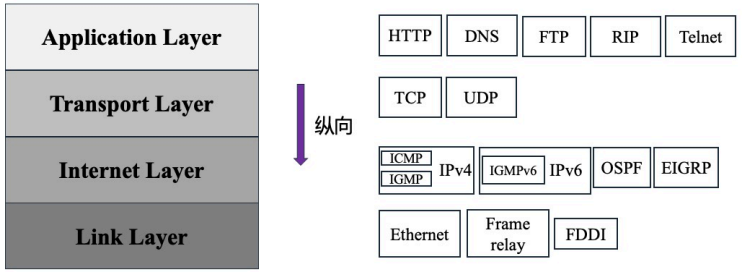
第四节：传输层安全
(1) 拒绝服务攻击
(2) TCP劫持攻击
(3) TLS协议

第1节 TCP/IP协议工作原理

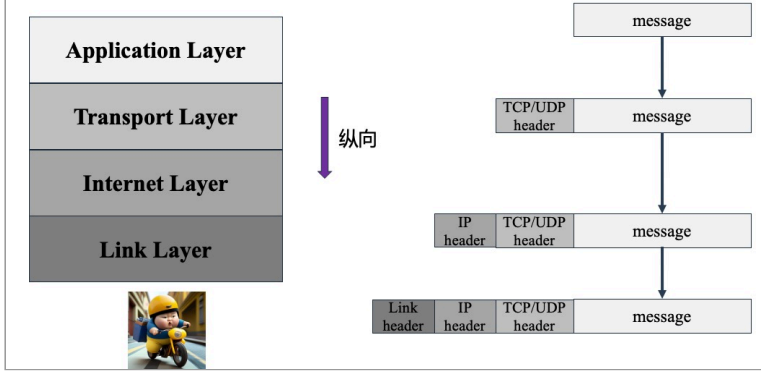
- 协议栈中消息的纵向传递
- 协议栈中消息的横向安全

雨课堂 Rain Classroom

协议栈中消息的纵向传递（消息传递与调用）

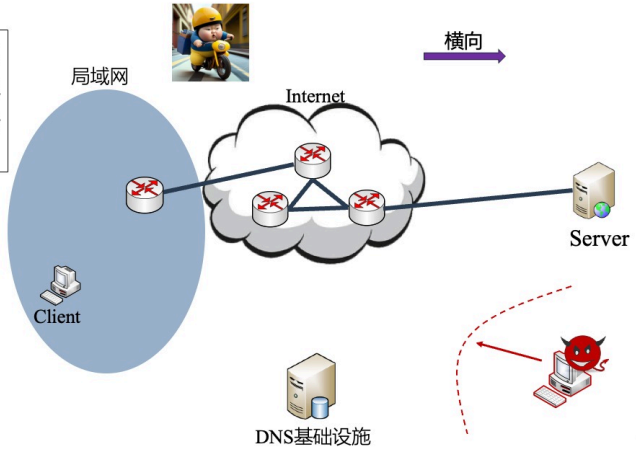


协议栈中消息的纵向传递



协议栈中消息的横向安全（抽象传递与语义安全）

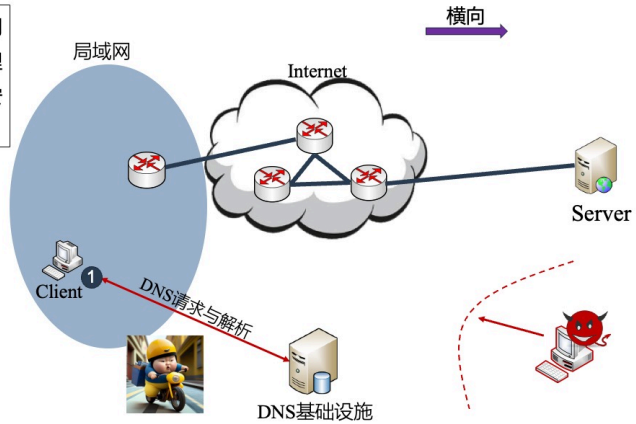
局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题



协议栈中消息的横向安全

局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题

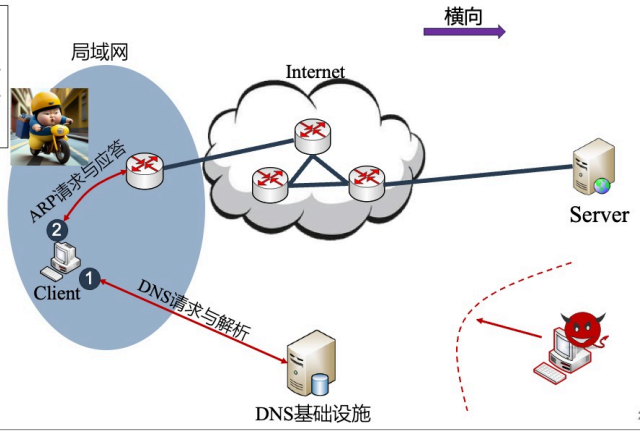
1. DNS劫持



协议栈中消息的横向安全

局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题

1. DNS劫持
2. ARP污染

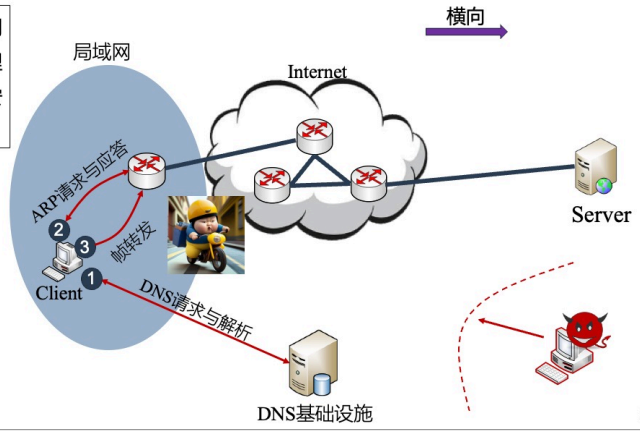


21

协议栈中消息的横向安全

局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题

1. DNS劫持
2. ARP污染
3. 嗅探监听

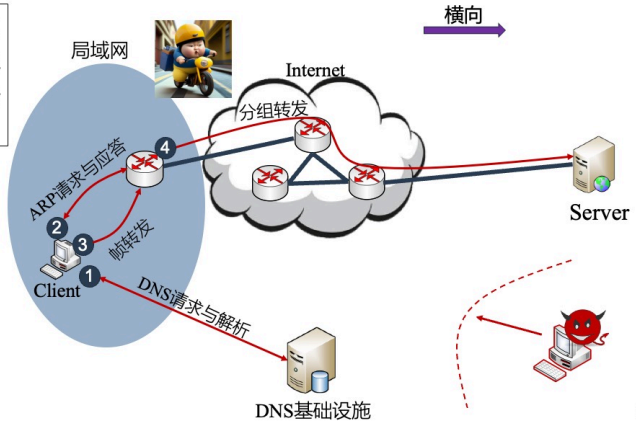


22

协议栈中消息的横向安全

局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题

1. DNS劫持
2. ARP污染
3. 嗅探监听
4. 地址伪造、路由劫持

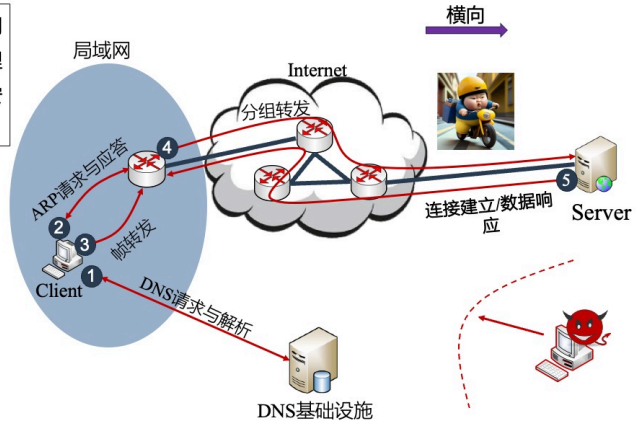


23

协议栈中消息的横向安全

局域网中的client远程访问Server时，在数据传递处理的每一步，都有可能产生安全问题

1. DNS劫持
2. ARP污染
3. 嗅探监听
4. 地址伪造、路由劫持
5. TCP连接劫持、DoS攻击



24

第2节 链路层安全

- 安全风险一: ARP欺骗与污染
- 安全风险二: 网络嗅探与网络监听

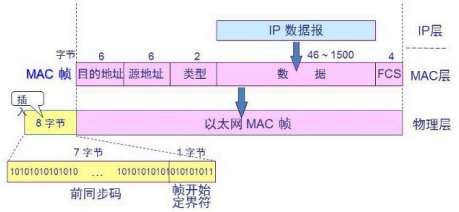
25

链路层功能

最基本的功能是向该层用户提供透明的和可靠的数据传送基本服务

功能主要有:

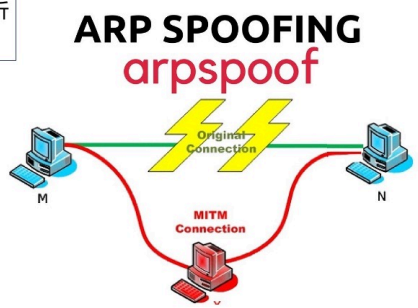
- 将数据组合成帧
- 控制帧在物理信道上的传输，包括处理传输差错，调节发送速率
- 提供数据链路通路的建立、维持和释放的管理



26

ARP欺骗与污染

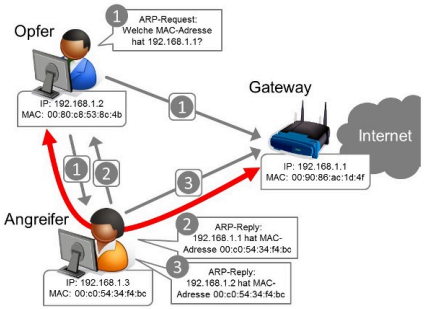
ARP欺骗（ARP spoofing），又称ARP污染（ARP poisoning），是针对以太网地址解析协议（ARP）的一种攻击技术



27

ARP欺骗与污染

可让攻击者成为中间人（Man-in-the-Middle, MITM），获取局域网上的数据包，甚至可篡改数据包，同时迫使受害主机无法正常接收报文

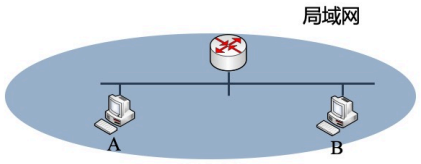


28

ARP欺骗与污染

拓扑示例：

局域网中的两台主机A、B，以及他们的IP地址和MAC地址：



主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

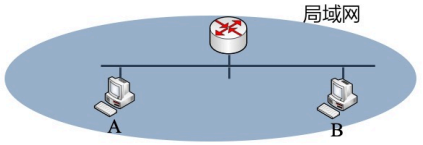
29

ARP欺骗与污染

主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

A、B间正常的ARP解析过程：

第1步：A主机在本地ARP缓存中，检查主机B的MAC地址



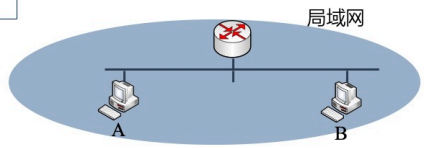
30

ARP欺骗与污染

主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

A、B间正常的ARP解析过程：

第2步：如果没有找到，询问192.168.1.2的硬件地址，将ARP请求帧广播到本地网络上的所有主机



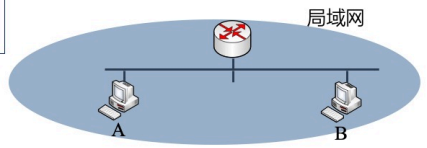
31

ARP欺骗与污染

主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

A、B间正常的ARP解析过程：

第3步：主机B确定ARP请求中的IP地址与自己的IP地址匹配，将主机A的IP地址和MAC地址映射，添加到本地ARP缓存中



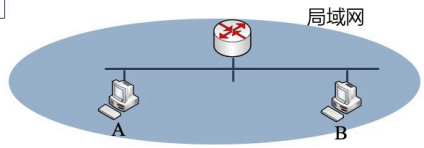
32

ARP欺骗与污染

主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

A、B间正常的ARP解析过程：

第4步：主机B将包含其MAC地址的ARP回复消息，直接发送回主机A

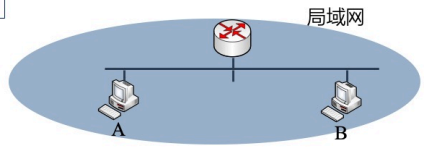


ARP欺骗与污染

主机	IP地址	MAC地址
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02

A、B间正常的ARP解析过程：

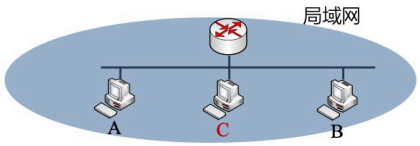
第5步：A收到回复，用主机B的IP和MAC地址映射更新ARP缓存



ARP欺骗与污染

安全问题：

在ARP回复时，主机A并不会验证ARP回复包的真实性。由此引出一个局域网攻击方式**ARP欺骗：**恶意主机C，企图冒充B，欺骗A



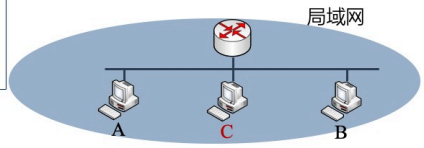
主机	IP	MAC
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02
C	192.168.1.3	0A-11-22-33-44-03

ARP欺骗与污染

主机	IP	MAC
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02
C	192.168.1.3	0A-11-22-33-44-03

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

第1步：主机A要和主机B通信，主机A发出ARP包询问谁是192.168.1.2? 请回复192.168.1.1。

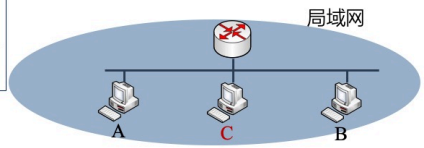


ARP欺骗与污染

主机	IP	MAC
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02
C	192.168.1.3	0A-11-22-33-44-03

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

第2步：主机C向主机A发送ARP应答报文，我是192.168.1.2，我的地址是0A-11-22-33-44-03



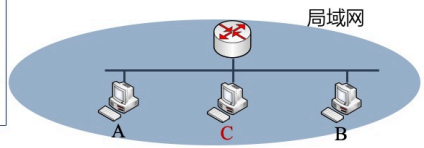
37

ARP欺骗与污染

主机	IP	MAC
A	192.168.1.1	0A-11-22-33-44-01
B	192.168.1.2	0A-11-22-33-44-02
C	192.168.1.3	0A-11-22-33-44-03

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

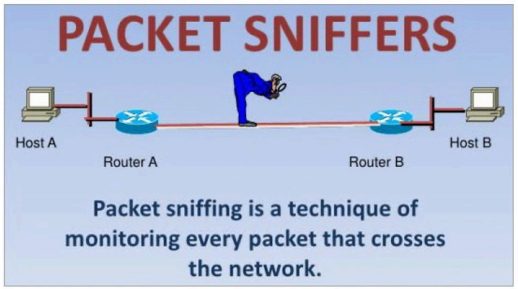
第3步：当A收到C发来的ARP回复消息时，会用主机**B的IP和C的MAC地址**映射，更新ARP缓存，从而实现了攻击者C对A发往B的流量的劫持



38

网络监听与嗅探

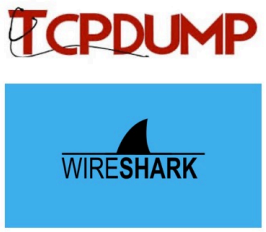
网络嗅探（Sniffers）是一种网络流量数据分析的手段，常见于网络安全攻防技术使用，也有用于业务分析领域

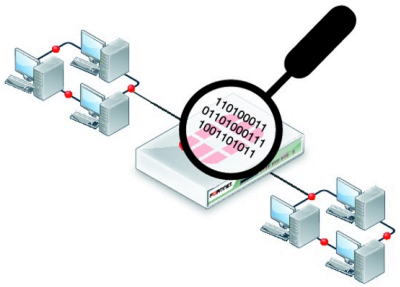


39

网络监听与嗅探

嗅探所使用的工具称为“嗅探工具”，也称为“数据包分析器”，还有别称为“嗅探器”、“抓包工具”等。常见的开源嗅探工具包括TCPDUMP，WIRESHARK等





40

网络监听与嗅探

网络嗅探具有两面性：

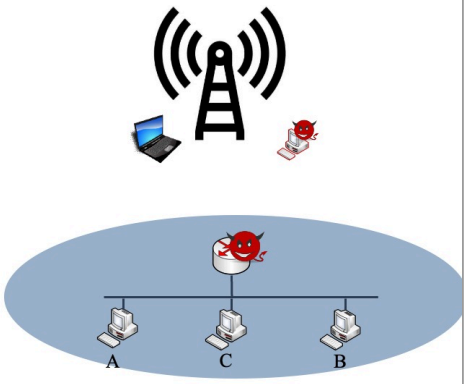
- 网络管理员使用嗅探器，通过捕获分析网络流量，进行高效的网络管理
- 恶意攻击者使用嗅探器，攫取网络中的大量敏感信息，进行网络攻击

41

网络监听与嗅探

恶意的网络嗅探，取决于攻击者的位置和攻击能力：

- 共享网络传输链路场景下，攻击者的恶意嗅探监听
- 攻击者控守了网络设备，对流经的流量进行拦截嗅探



42

网络监听与嗅探的底层技术支持——eBPF

网络嗅探的痛点：

- 将所有数据包从内核空间复制到用户空间，产生大量内存拷贝和上下文切换

BPF（Berkeley Packet Filter/BSD Packet Filter）

- Steven McCanne, Van Jacobson@1992，Lawrence Berkeley Laboratory
- 设计1个运行在Linux内核中的轻量级、安全的虚拟机
  - 数据包在内核中直接被BPF虚拟机过滤，只有匹配的包才被复制到用户空间
  - 性能：提高百倍
  - 缺点：过滤逻辑简单，难以进行复杂的分析
  - 改进：引入零拷贝技术、JIT技术……

eBPF（extended BPF）@2014

- 2个32位寄存器 → 10个64位寄存器
- 支持复杂逻辑、静态分析进行安全验证、用于非安全用途

43

网络监听与嗅探

2013年6月5日，前美国中央情报局雇员斯诺登向英国《卫报》和美国《华盛顿邮报》爆料，曝光了美国国家安全局（NSA）等美国政府部门监视公民隐私的“棱镜（PRISM）”计划，举世哗然

44

网络监听与嗅探

“棱镜”计划监视范围很广。情报人员通过“后门”进入9家主要科技公司的服务器，包括微软、雅虎、谷歌、Facebook、PalTalk、美国在线、Skype、YouTube、和苹果

服务器有什么？是可信任的吗？

facebook Microsoft CISCO

45

第3节 网络层安全

- **攻击举例: 伪造与拒绝服务**
- 防御举例: 安全协议与入侵检测
- 专题：路由协议安全——域内与域间

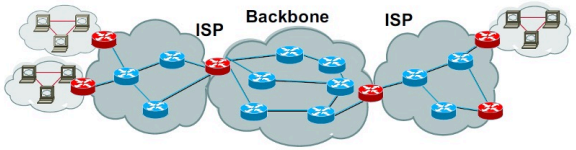
46

网络层功能

网络层介于传输层和数据链路层之间，向传输层提供最基本的端到端的数据传送服务

网络层具备的功能包括:

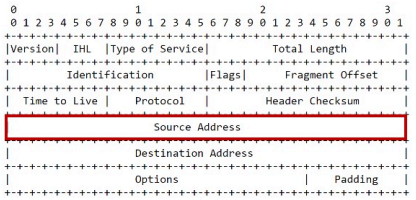
- 分组与分组交换
- 路由
- 网络互联
- 网络连接复用
- 差错检测与恢复
- 服务选择
- 网络管理
- 分片与重组

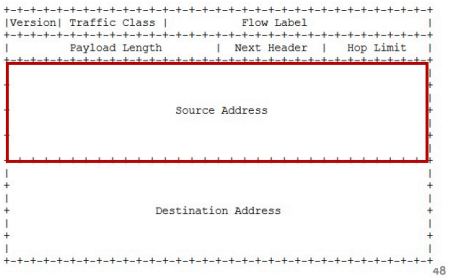


47

源地址假冒攻击

IP地址用于唯一的标识互联网上的一个网络通信接口

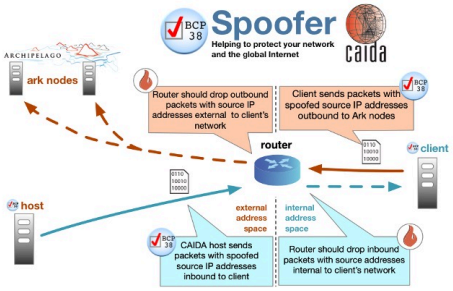




48

源地址假冒攻击

互联网在设计之初，对分组的源IP地址并不进行合法性验证，因此恶意的攻击者很容易篡改或伪造分组的源IP地址

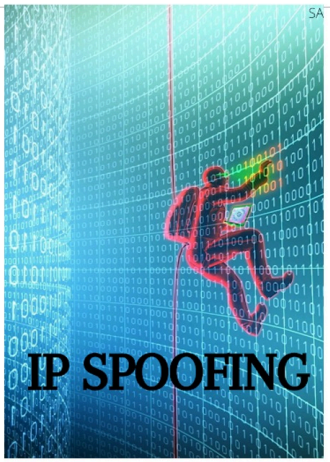


源地址假冒攻击

网络层的源IP地址假冒攻击（IP spoofing），是最常见的一种针对IP协议的攻击

通常，IP spoofing也是进行复杂网络攻击，如会话劫持，DNS污染、TCP劫持等攻击的能力基础和先决条件

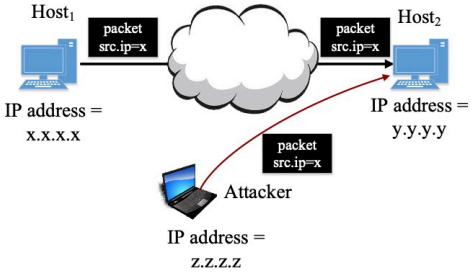
可以连续伪造IP数据包（不能收）；
可以伪造有连接协议的第一个数据包；
如果找到缺陷，也可以伪造有连接协议的连续数据包（劫持）。



源地址假冒攻击

攻击原理

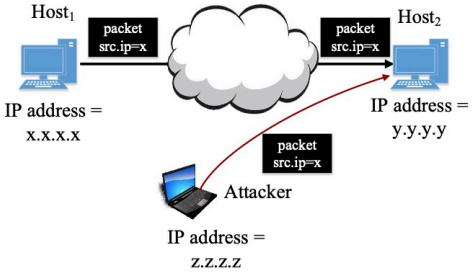
$Host_1$和$Host_2$为正常合法通信的两台主机，IP地址分别为：x.x.x.x 和 y.y.y.y



源地址假冒攻击

攻击原理

恶意攻击者Attacker，其真实IP地址为z.z.z.z，Attacker企图冒充$Host_1$，发动源IP地址伪造攻击

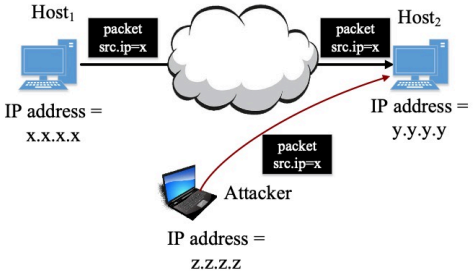


雨课堂 Rain Classroom

源地址假冒攻击

攻击原理

Attacker生成恶意分组，发送给主机$Host_2$，并且将分组的源地址指定为x.x.x.x

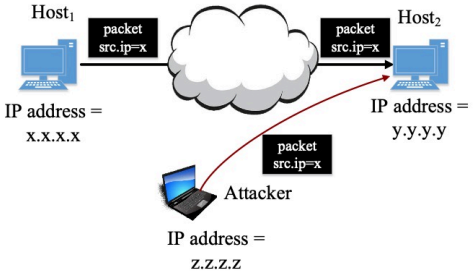


源地址假冒攻击

攻击原理

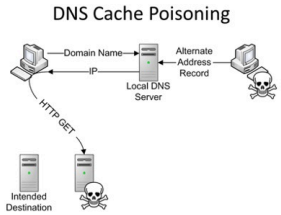
最终的后果是：

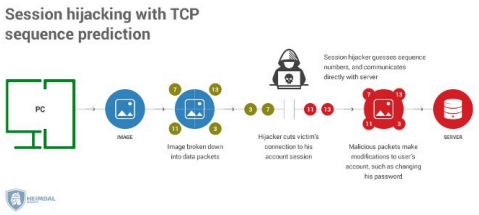
- Attacker欺骗了主机$Host_2$，使其误认为这些分组来自于合法的远程通信端$Host_1$
- Attacker也隐藏了自己的真实地址和身份，避免被追踪溯源



源地址假冒攻击

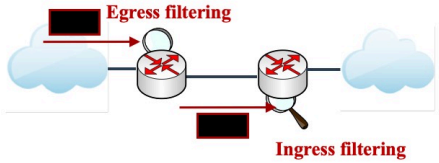
IP地址伪造通常是攻击者需具备的基本能力和手段，也是进行后续恶意数据注入、连接劫持等攻击行为的基础条件，如TCP连接劫持攻击、DNS污染攻击等





源地址假冒攻击

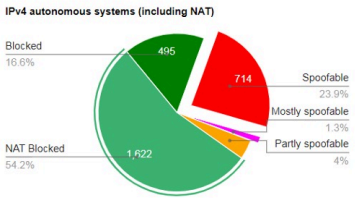
随着真实地址、真实身份等技术标准的出现，这一问题得到了缓解，但要彻底解决这一攻击威胁，仍需持续的技术推动和投入



RFC 2827，RFC 3704，RFC 5210，RFC 8704

源地址假冒攻击

根据CAIDA Spoofer的数据显示，目前互联网上仍然有**23.9% 的IPv4**地址可以被伪造

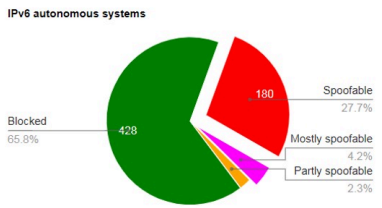


Status	Count
Spoofable	714
Mostly spoofable	40
Partly spoofable	119
NAT Blocked	1622
Blocked	495

https://spoofer.caida.org/summary.php, 2020年10月

源地址假冒攻击

根据CAIDA Spoofer的数据显示，目前互联网上仍然有**27.7% 的IPv6**地址可以被伪造

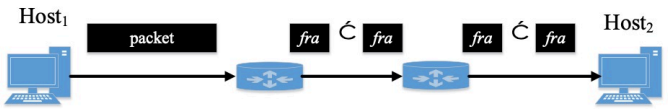


Status	Count
Spoofable	180
Mostly spoofable	27
Partly spoofable	15
Blocked	428

https://spoofer.caida.org/summary.php, 2020年10月

IP分片攻击原理

当互联网上的两台远程主机进行数据传输时，如果传输路径上的各跳间，存在不同的链路最大传输单元（Maximum Transmission Unit，MTU），那么可能会发生IP分组分片（IP fragmentation），以满足链路MTU的要求

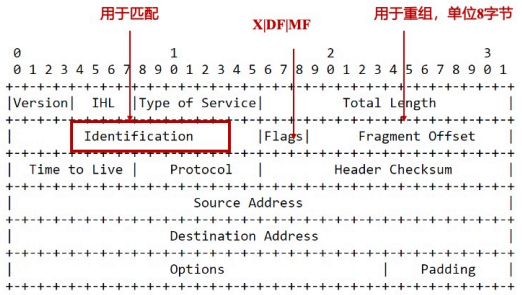


如果上一个攻击是协议的锅，那这个攻击只能怪罪程序员了（已修复）

IP分片攻击原理

所有的IP分片到达目的接收端后，接收端对这些分片进行重组，还原出原来的IP分组，再提交给上层进行处理

分片的重组依赖于IPID字段，而原始IP分组是否允许被分片，取决于Flags字段中的DF位



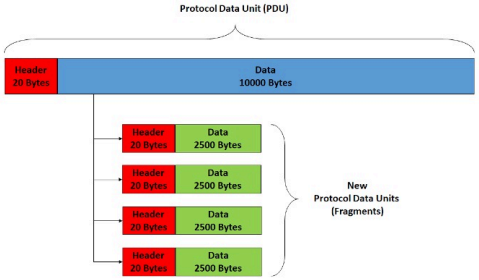
X | DF | MF

保留 1：禁止分片 1：还有分片
0：允许分片 0：最后一个

IP分片攻击原理

IP分组的这种先分片、再重组的机制，为攻击者暴露出了IP层的一个攻击面。分组的碎片化发生在源主机或中间路由器上，而重组往往都在目的接收端发生。根据不同的攻击效果，IP碎片攻击可以分为3种

- 拒绝服务攻击
- 污染攻击
- 安全策略逃逸



61

IP分片攻击原理

- 拒绝服务攻击

理论上一个IP分组的最大长度是65535字节，攻击者可以发送一个长度超过65535字节IP分组，迫使接收端在对分片重组时，有概率造成异常错误。

why

62

IP分片攻击原理

- 拒绝服务攻击

Ping of Death：攻击者通过发送长度超过65535字节的Echo Request数据包给目标主机，该数据包经过中间路由器的分片，然后到达目标主机

63

IP分片攻击原理

- 拒绝服务攻击

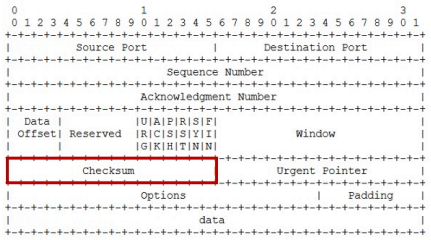
早期的一些TCP/IP协议栈实现（如Windows98之前的Windows操作系统），存在内存分配错误，会发生事先分配的65535字节缓冲区溢出，从而引起系统崩溃或挂起，造成拒绝服务攻击

64

IP分片攻击原理

- 拒绝服务攻击

其他的利用IP分片进行DoS攻击的技术：如伪造分片和原始合法分片错误重组，导致TCP或UDP报文的校验和出错，造成正常报文的丢失



TCP Header Format

Note that one tick mark represents one bit position.

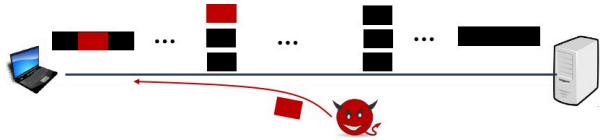
65

IP分片攻击原理

- 污染攻击

利用IP分片进行污染攻击是一种更高级的攻击方式。

在原始报文被分片、传输过程中，攻击者伪造一些分片，注入到正常分片流中，篡改原始报文内容，从而形成对合法流量的污染



66

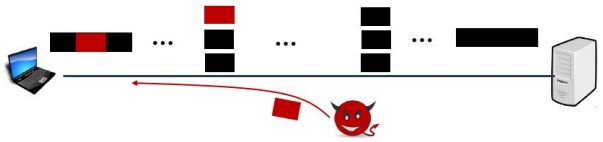
IP分片攻击原理

- 污染攻击

在这一过程中，攻击者需要具备的能力：

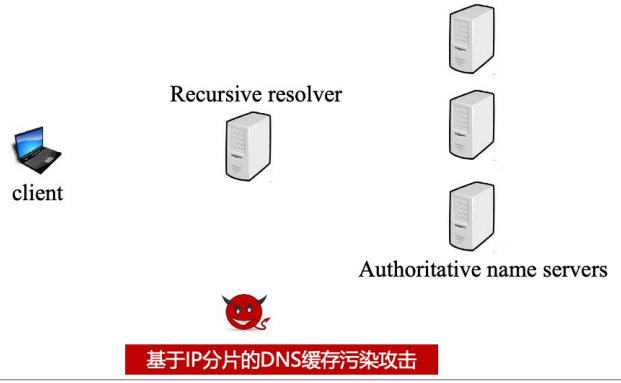
- ◆ 源地址欺骗
- ◆ IPID的猜测
- ◆ 原始报文校验和的欺骗等

基于分片的污染攻击技术，已被广泛应用到DNS缓存污染、流量拦截等场景中



67

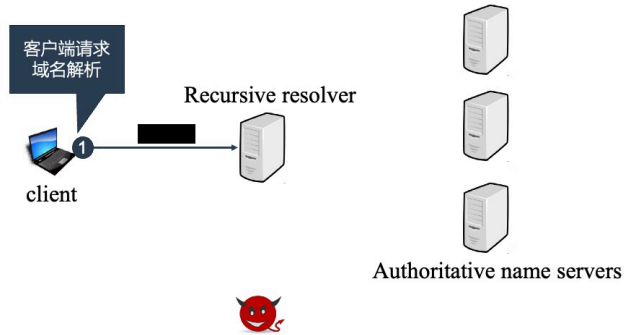
IP分片攻击原理



基于IP分片的DNS缓存污染攻击

68

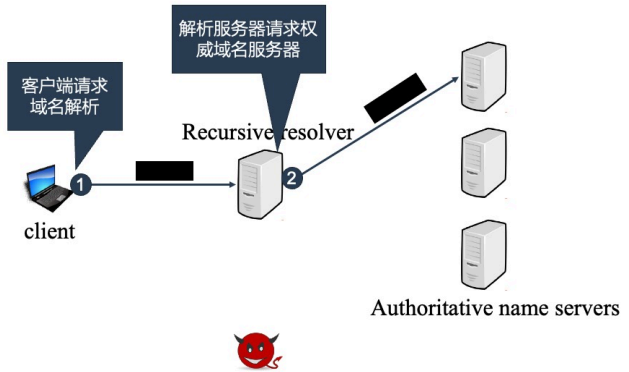
IP分片攻击原理



基于IP分片的DNS缓存污染攻击

69

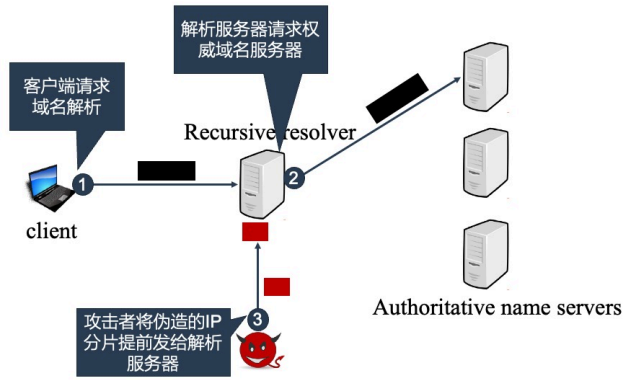
IP分片攻击原理



基于IP分片的DNS缓存污染攻击

70

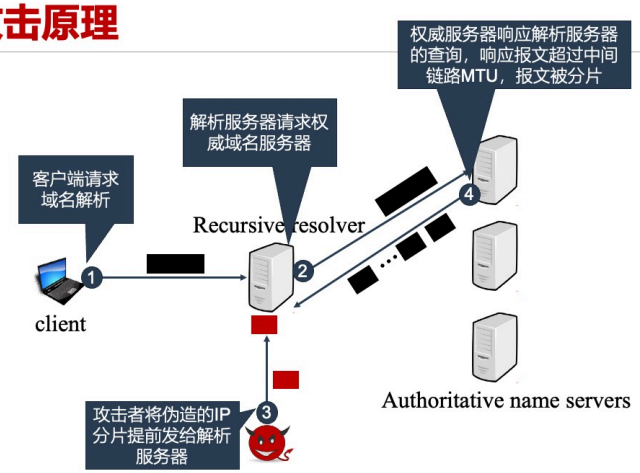
IP分片攻击原理



基于IP分片的DNS缓存污染攻击

71

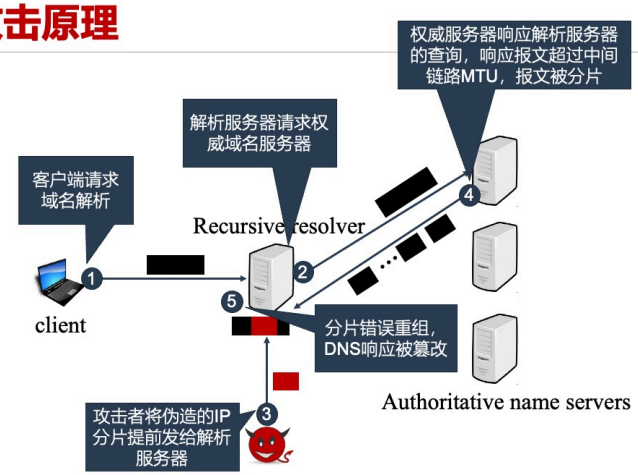
IP分片攻击原理



基于IP分片的DNS缓存污染攻击

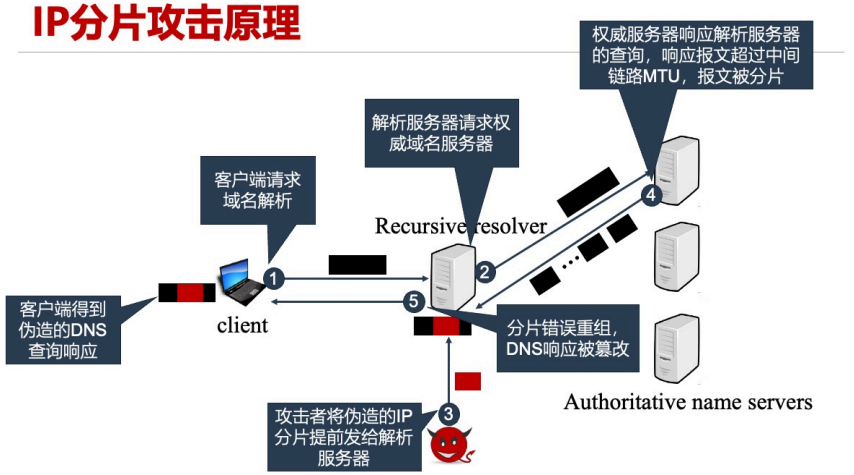
72

IP分片攻击原理



基于IP分片的DNS缓存污染攻击

IP分片攻击原理



基于IP分片的DNS缓存污染攻击

IP分片攻击原理

Offsets	Octet	0								1								2								3							
Octet	Bit	0	1	2	3	4	5	6	7	8	9							23	24	25	26	27	28	29	30	31							
0	0	v4				IHL = 20												Length = 85															
4	32	IPID = 23456																Frag Offset = 48															
8	64	TTL								P								der Checksum															
12	96																																
16	128	nation IP = 7.7.7.7																															
20	160	Data Length = 4																IPv4 Address															
24	192	6.6.6.6																Name = 0									Type						
28	224	= OPT								UDP Payload Size = 4096																	EXTENDED-RCODE = 0						
32	256	Version = 0								DO	Z																Data Length						
36	288	= 0																															

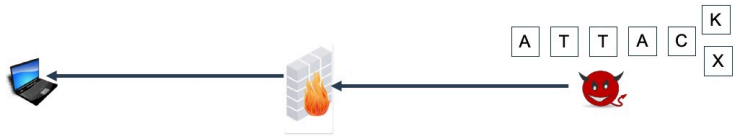
利用IP分片，将域名的合法IP地址，篡改成攻击者控制的地址“6.6.6.6”，实现域名劫持

基于IP分片的DNS缓存污染攻击

IP分片攻击原理

- 安全策略逃逸

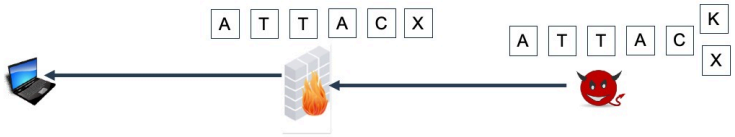
通常网络防火墙会对IP分片进行重组，然后审查其中的恶意载荷。但防火墙和接收端主机往往存在重组策略不一致现象，即当分片出现重叠时，二者可能会采用不同的覆盖策略



IP分片攻击原理

- 安全策略逃逸

因此，攻击者可以通过设置合理的分片偏移，逃逸防火墙的审查，但形成对接收端的破坏

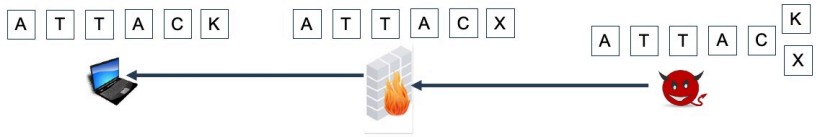


77

IP分片攻击原理

- 安全策略逃逸

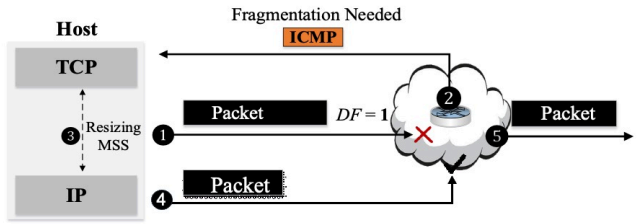
因此，攻击者可以通过设置合理的分片偏移，逃逸防火墙的审查，但形成对接收端的破坏



78

IP分片攻击原理

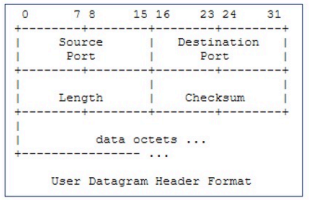
TCP协议有MSS选项，可以通过调整MSS、适合路径MTU，从而避免分片。UDP？



79

IP分片攻击原理

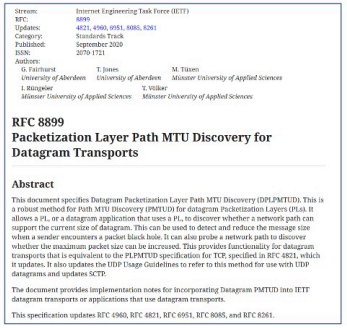
UDP是面向事务的，与IP层是松耦合的，UDP报文的大小直接由应用给定，因此UDP不能依据路径MTU大小、对传输层报文进行适应性调整，即针对UDP报文的IP分片很难避免



80

IP分片攻击原理

新的RFC标准提出，应用层和UDP协议合作、发现路径MTU，从而避免IP分片，但这些新标准和机制的实际部署，仍需很长时间



Stream: Internet Engineering Task Force (IETF)
RFC: 8899
Updates: 4821, 4960, 6951, 8085, 8261
Category: Standards Track
Published: September 2020
ISSN: 2070-1721
Authors:
G. Fairhurst, University of Aberdeen
T. Jones, University of Aberdeen
M. Tüxen, Münster University of Applied Sciences
I. Rüngeler, Münster University of Applied Sciences
T. Völker, Münster University of Applied Sciences

RFC 8899
Packetization Layer Path MTU Discovery for Datagram Transports

Abstract

This document specifies Datagram Packetization Layer Path MTU Discovery (DPLPMTUD). This is a robust method for Path MTU Discovery (PMTUD) for datagram Packetization Layers (PLs). It allows a PL, or a datagram application that uses a PL, to discover whether a network path can support the current size of datagram. This can be used to detect and reduce the message size when a sender encounters a packet black hole. It can also probe a network path to discover whether the maximum packet size can be increased. This provides functionality for datagram transports that is equivalent to the PLPMTUD specification for TCP, specified in RFC 4821, which it updates. It also updates the UDP Usage Guidelines to refer to this method for use with UDP datagrams and updates SCTP.

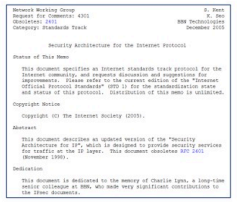
The document provides implementation notes for incorporating Datagram PMTUD into IETF datagram transports or applications that use datagram transports.

This specification updates RFC 4960, RFC 4821, RFC 6951, RFC 8085, and RFC 8261.

IPSec协议

IPSec（Internet Protocol Security，RFC4301），即Internet协议安全性，是一种开放标准的框架结构，通过对IP协议的分组进行加密和认证，来保护基于IP协议的网络传输

在 IPv4 中， IPSec 的使用是一个可选项，在 IPv6 （RFC 6434 ）中，初始设为必选项，为了随着 IPv6 的进一步流行，IPSec 可以得到更为广泛的使用



Network Working Group
Request for Comments: 4301
Obsoletes: 2401
Category: Standards Track

S. Kent
K. Seo
BBN Technologies
December 2005

Security Architecture for the Internet Protocol

Status of This Memo

This document specifies an Internet standards track protocol for the Internet community, and requests discussion and suggestions for improvements. Please refer to the current edition of the "Internet Official Protocol Standards" (STD 1) for the standardization state and status of this protocol. Distribution of this memo is unlimited.

Copyright Notice

Copyright (C) The Internet Society (2005).

Abstract

This document describes an updated version of the "Security Architecture for IP", which is designed to provide security services for traffic at the IP layer. This document obsoletes RFC 2401 (November 1998).

Dedication

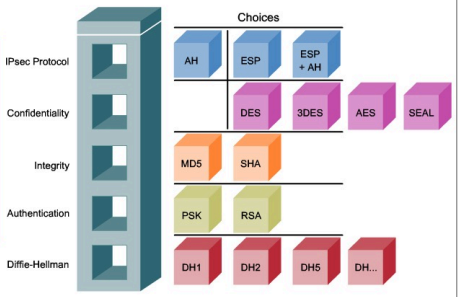
This document is dedicated to the memory of Charlie Lynn, a long-time senior colleague at BBN, who made very significant contributions to the IPsec documents.

IPSec协议

IPSec协议工作在TCP/IP协议的第三层，使其在单独使用时适于保护基于IP协议的所有上层协议

IPSec提供了两种安全机制：

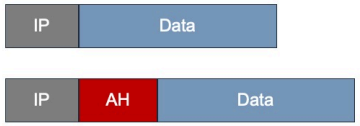
- 认证，采用IPSec的Authentication Headers，AH
- 加密，采用IPSec的Encapsulating Security Payloads，ESP



IPSec协议

- 认证机制（AH，IP协议号为51）

提供数据源认证、数据完整性校验和防报文重放功能，它能保护通信免受篡改，但不能防止窃听，适合用于传输非机密数据



IPSec协议

- 认证机制（AH，IP协议号为51）

AH的工作原理是在每一个数据包上添加一个身份验证报文头，此报文头插在标准IP包头后面，对数据提供完整性保护。可选择的认证算法有MD5（Message Digest）、SHA-1（Secure Hash Algorithm）等

85

IPSec协议

- 加密机制（ESP，IP协议号为50）

提供加密、数据源认证、数据完整性校验和防报文重放功能。ESP的工作原理是在每一个数据包的标准IP包头后面添加一个ESP报文头，并在数据包后面追加一个ESP尾

86

IPSec协议

- 加密机制（ESP，IP协议号为50）

与AH协议不同的是，ESP将需要保护的用户数据进行加密后再封装到IP包中，以保证数据的机密性。常见的加密算法有DES、3DES、AES等。同时，作为可选项，用户可以选择MD5、SHA-1算法保证报文的完整性和真实性

87

IPSec协议

在实际进行IP通信时，可以根据实际安全需求同时使用这两种协议或选择使用其中的一种

同时使用AH和ESP时，设备支持的AH和ESP联合使用的方式为：先对报文进行ESP封装，再对报文进行AH封装

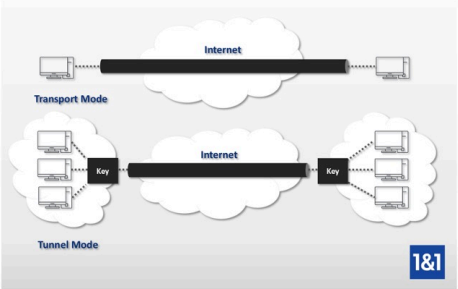
封装之后的报文从内到外依次是原始IP报文、ESP头、AH头和外部IP头

88

IPSec协议

IPSec的两种工作模式：

- 传输（transport）模式：只是传输层数据被用来计算AH或ESP头，AH或ESP头以及ESP加密的用户数据被放置在原IP包头后面
- 隧道（tunnel）模式：用户的整个IP数据包被用来计算AH或ESP头，AH或ESP头以及ESP加密的用户数据被封装在一个新的IP数据包中



IPSec协议

IPSec的工作模式：

- 传输模式

主要用于主机和主机之间，端到端通信的数据保护

封装方式：不改变原有的IP包头，在原数据包头后面插入IPSec包头，只封装数据部分

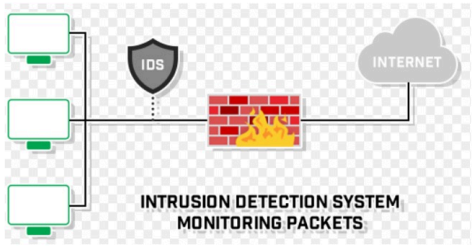
- 隧道模式

主要用于私网与私网之间，通过公网进行通信，建立安全VPN通道。

封装方式：增加新的IP（外网IP）头，其后是IPSec包头，之后再将原来的整个数据包封装

防护→检测：网络入侵检测系统

入侵检测系统（Intrusion Detection System, IDS）是一种网络安全设备或应用软件，可以监控网络数据传输（NIDS），或者主机系统行为（HIDS），检查是否有可疑活动或者违反预定义的安全策略

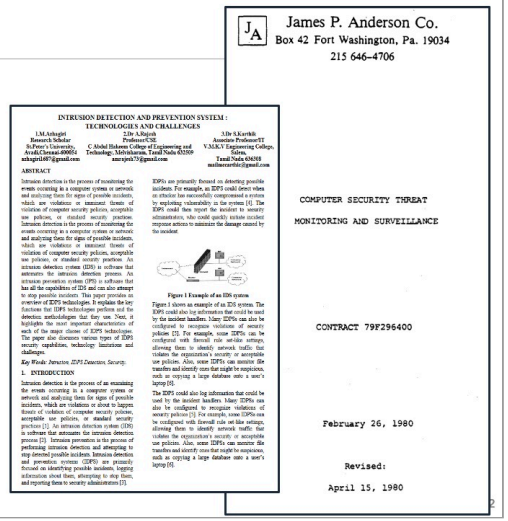


网络入侵检测系统

IDS的起源，最早可以追溯到1980年4月，James P. Anderson为美国空军做了一份题为《Computer Security Threat Monitoring and Surveillance》的技术报告。

1980年代中期，IDS逐渐发展成为入侵检测专家系统（IDES）

1990年，IDS分化为基于网络的NIDS和基于主机的HIDS，后又出现分布式D-IDS


INTRUSION DETECTION AND PREVENTION SYSTEM : TECHNOLOGIES AND CHALLENGES

ABSTRACT

James P. Anderson Co.
Box 42 Fort Washington, Pa. 19034
215 646-4706

COMPUTER SECURITY THREAT MONITORING AND SURVEILLANCE

CONTRACT 79F296400

February 26, 1980

Revised:

April 15, 1980

雨课堂 Rain Classroom

网络入侵检测系统

从主要技术途径上区分，IDS主要分为两类：

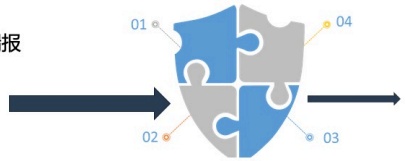
Expert System

(1) 基于特征匹配的IDS

基于专家知识或经验，预定义攻击行为特征或规则，然后对网络流量或主机行为进行匹配，如果匹配成功，则判定为攻击事件

优点：误报率低，检测速度快

缺点：无法识别未知攻击，存在漏报



网络入侵检测系统

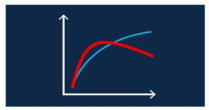
从主要技术途径上区分，IDS主要分为两类：

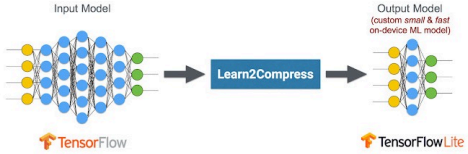
(2) 基于异常检测的IDS

首先通过学习建模的方法，构建网络或主机的正常行为基线。然后结合当前网络或主机态势进行判断，如果网络或主机的行为偏离该基线，则判断发生了入侵或攻击，进行告警

优点：可以识别未知攻击

缺点：存在误报，检测速度慢



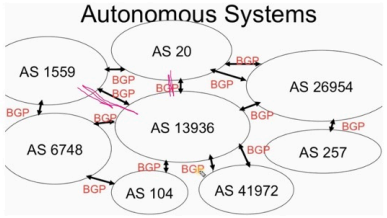


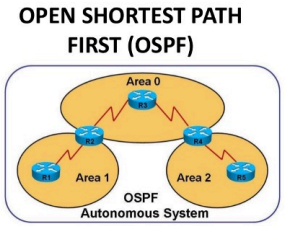
路由安全

路由（routing）是通过互联的网络，把信息从源地址传输到目的地址的活动。路由发生在TCP/IP协议的第三层即网络层。路由引导分组转送，经过一些中间的节点后，到它们最后的目的地

路由安全

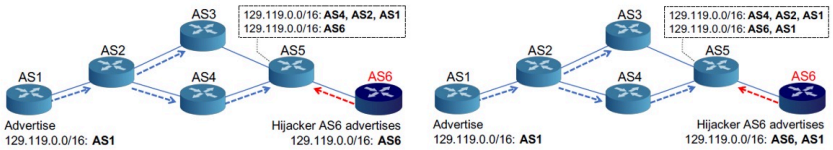
Internet被划分为多个自治系统（AS），每个自治系统可以制定自己的路由策略。自治系统内部的路由器通过域内路由协议彼此交换路由信息；自治系统边界路由器通过域间路由协议交换路由信息





域间路由安全

AS （恶意攻击者）宣告一个其实际上并不控制的IP地址前缀，进行虚假路由宣告。如果虚假路由宣告未被有效过滤，就有可能发生路由劫持攻击

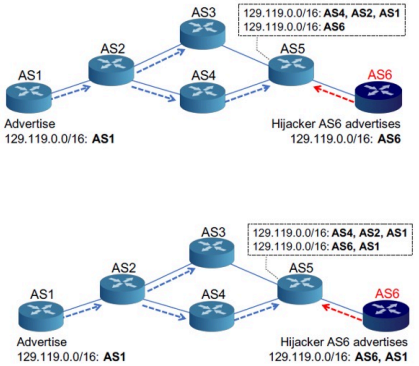


域间路由安全

BGP 劫持成功，恶意攻击者的宣告必须满足以下条件：

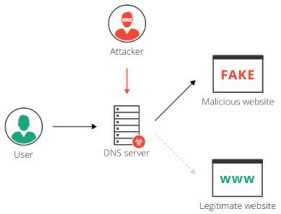
（1）宣告比以前其他 AS 更具体的 IP 地址范围
（2）提供一条通往目标IP 地址块的较短路径

需要注意的是，要发生 BGP 劫持，通常需要 AS 的运营商权限



域间路由安全

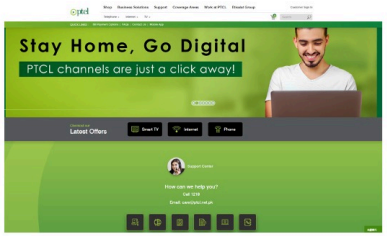
2018年，黑客通过BGP劫持了亚马逊DNS查询，窃取了大约152,000美元的加密货币



2015年，被爆出意大利国家军事警察的特别行动组，与意大利网络运营商Aruba S.p.A（AS31034）合作，通过BGP劫持目标网络的链接

域间路由安全

2008年，巴基斯坦电信劫持YouTube流量，导致YouTube断网2小时，全球很多用户无法访问

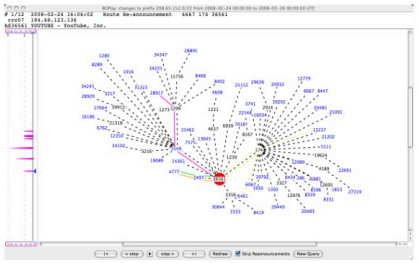


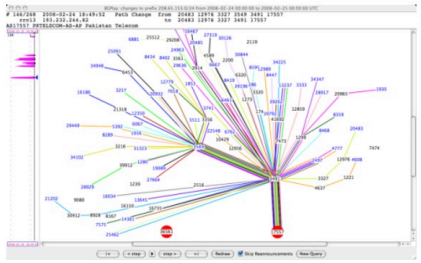
YouTube

域间路由安全

AS36561 (YouTube) 通告208.65.152.0/22

AS17557 (Pakistan Telecom) 通告208.65.153.0/24劫持YouTube流量





101

域间路由安全

目前，针对BGP协议暴露出的安全问题，已有相关的安全标准被提出，但这些标准技术的实际部署，还需要很长一段时间

- RFC 8205 - BGPsec Protocol Specification
- RFC 8206 - BGPsec Considerations for Autonomous System (AS) Migration
- RFC 8207 - BGPsec Operational Considerations
- RFC 8208 - BGPsec Algorithms, Key Formats, and Signature Formats
- RFC 8209 - A Profile for BGPsec Router Certificates, Certificate Revocation Lists, and Certification Requests

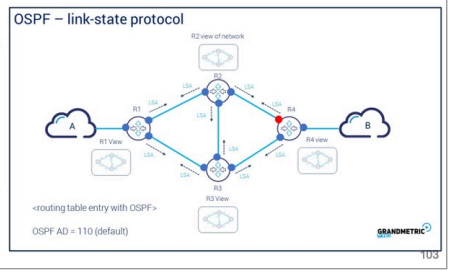
102

域内路由安全

OSPF协议是目前使用最广泛的域内路由协议，因此针对域内路由的威胁攻击，也主要是针对OSPF协议展开

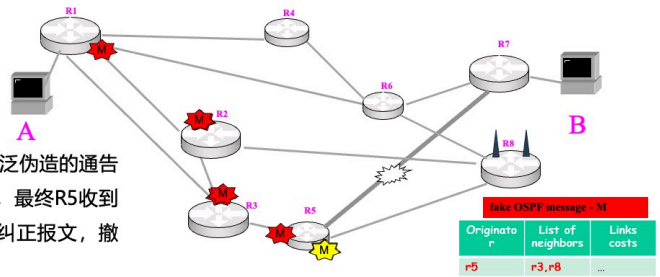
OSPF攻击基本原理：

攻击者通常假装成合法的域内路由器，伪造多个OSPF协议的LSA报文广播出去，迷惑其他路由器路由表的计算



103

域内路由安全



- Fight-back安全机制

恶意路由器R1冒充R5洪泛伪造的通告M（其中缺少邻居R7），最终R5收到该伪造消息后，会发送纠正报文，撤销该虚假通告

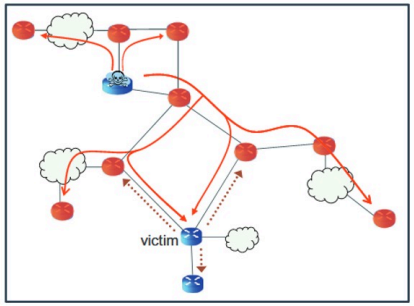
因此，现有关于OSPF协议的威胁破坏，其核心就是如何在伪造LSA的时候，避免触发源合法路由器的fight-back机制

104

域内路由安全

- Periodic injection 攻击

（1）fight-back纠正报文的通告是有时限的，路由器LSA报文的通告不能小于5秒

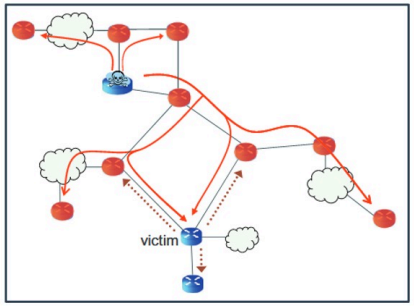


105

域内路由安全

- Periodic injection 攻击

（2）如果攻击者发送伪造LSA的间隔小于5秒，源合法路由器发现伪造的LSA与当前时刻小于5秒，会阻止当前的fight-back动作

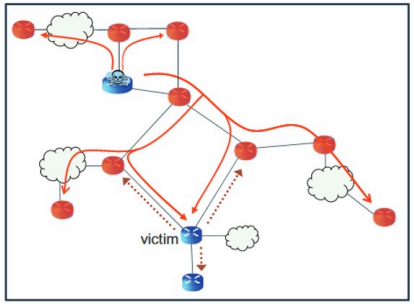


106

域内路由安全

- Periodic injection 攻击

（3）等待时钟到达5秒后再发送，但是当真的再过5秒后，下一个伪造的LSA又会到达，则源合法路由器又会继续等待，从整体效果来看，整个fight-back动作被抑制了



107

域内路由安全

- Disguised LSA 攻击

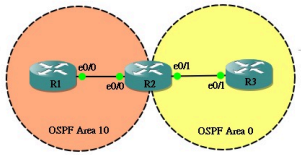
在判别两个LSA报文相同与否时，OPSF主要是依靠LSA报文中的Sequence Number, Checksum, 和Age三个字段判断，而不是报文内容的全匹配

Common LSA 20-byte Packet Header

Bit/ Byte	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
0	LS Age																LS Type															
32	Link State ID																															
64	Advertising Router																															
96	LS Sequence Number																															
128	LS Checksum																Length															
160	Depending on the "LS Type" details of the contents will vary. (Details of each LS Type are listed below.)																															
192																																
~																																
~																																
~																																
~	...																															

雨课堂 Rain Classroom

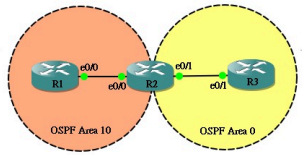
域内路由安全



- Disguised LSA 攻击

（1）如果攻击者能够预测出源合法路由器发送的 fight-back 报文的这三个值，那么他可以依据这三个值来伪造LSA报文

域内路由安全



- Disguised LSA 攻击

（2）这样即使该伪造报文被广播到源合法路由器、路由器fight-back一个纠正报文，但是其他路由器接收到该纠正报文后，会认为该报文是一个重复报文，丢弃掉，导致fight-back机制失效

目前，随着OSPF协议的不断改进，之前的安全漏洞大多已被修补，其安全性也已大为改善

第4节 传输层安全

- 拒绝服务攻击
- TCP劫持
- 安全协议：TLS协议

传输层功能

传输层主要负责提供不同主机应用程序进程之间的端到端的服务

传输层的基本功能如下：

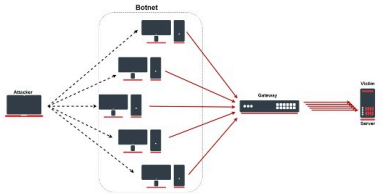
- 分割与重组数据
- 按端口号寻址
- 连接管理
- 差错控制和流量控制、纠错的功能

常见的传输层协议主要包括两类：TCP（Transmission Control Protocol）和UDP（User Datagram Protocol）

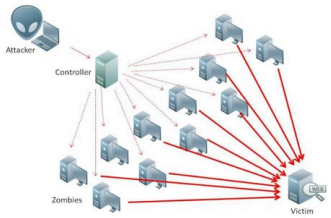
雨课堂 Rain Classroom

拒绝服务攻击

拒绝服务（Denial of Service，DoS）是指任何对服务的干涉，使得其可用性降低或者失去可用性。例如一个计算机系统崩溃，或其带宽耗尽，或其硬盘被填满，导致其不能提供正常的服务，就构成拒绝服务

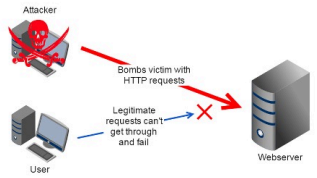


拒绝服务攻击



最常见的DoS攻击有计算机网络带宽攻击和连通性攻击:

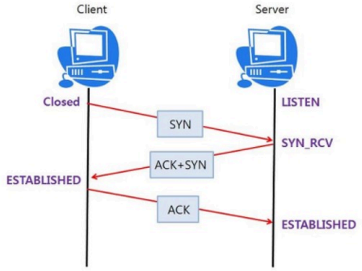
- 带宽攻击指以极大的通信量冲击网络，使得所有可用网络资源都被消耗殆尽
- 连通性攻击指用大量的连接请求冲击计算机，使得所有可用的操作系统资源都被消耗殆尽



拒绝服务攻击

SYN Flooding是针对TCP协议主要的DoS攻击方式之一，通过发送大量伪造的TCP连接请求，使被攻击方资源耗尽，CPU满负荷或内存不足

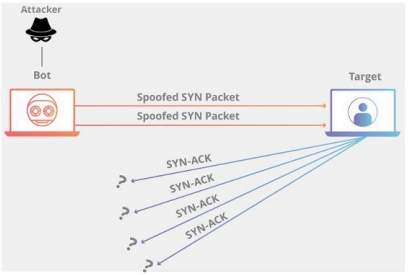
SYN Flooding攻击，发生在TCP协议中的三次握手（Three-way Handshake）阶段



拒绝服务攻击

SYN Flooding攻击

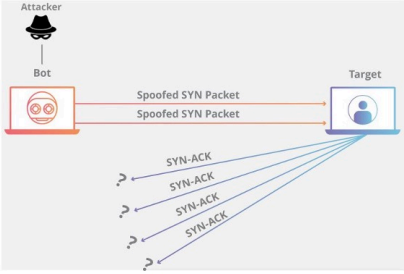
（1）攻击者向目标服务器发送大量伪造的SYN数据包，通常会使用欺骗性的IP地址



拒绝服务攻击

SYN Flooding攻击

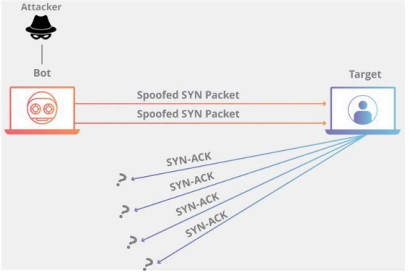
（2）服务器响应每个连接请求，并分配存储和计算资源，维护半连接状态



拒绝服务攻击

SYN Flooding攻击

（3）攻击者继续发送更多的SYN数据包，每个新的SYN数据包的到达都会消耗服务器端的资源，最终资源消耗殆尽，服务器就无法正常工作



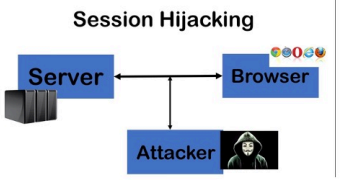
SYN Flooding还有很多变种，包括SYN-ACK Flooding等。针对这种类型的攻击，目前OS内核层面已经有一些防御措施，如SYN Cookie（RFC4987）等

TCP劫持攻击

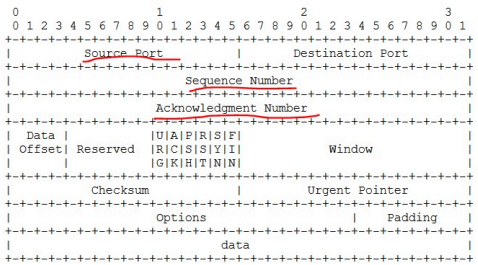
相比较针对TCP的DoS攻击，针对TCP的劫持攻击是一种更高级、更隐蔽、危害也更大的攻击方式

TCP劫持攻击是指，一个TCP连接外的非法攻击者（即Client和Server之外的一个Attacker），将自己伪造的TCP报文，注入到TCP连接双方的合法数据流中，进而对连接进行攻击破坏，包括：

- 伪造控制报文、如RST报文等，恶意阻断该连接
- 伪造数据报文，污染数据流



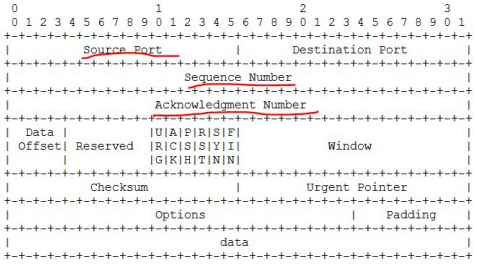
TCP劫持攻击



TCP协议的实现引入了32位随机的序列号和确认号，以及16位随机的源端口号。因此攻击者要成功地将恶意报文注入到目标TCP流中，必须正确预测这些值

雨课堂 Rain Classroom

TCP劫持攻击

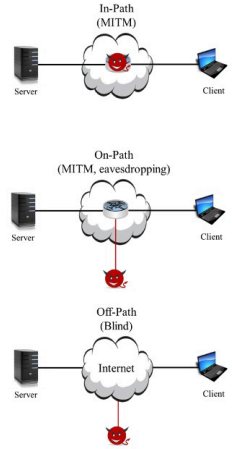


如果采用暴力猜测的办法，要求攻击者的报文发送能力大约在300M个/s。这在实际环境中，显然很难成功实施，也很容易触发IDS等安全检测设备

TCP劫持攻击

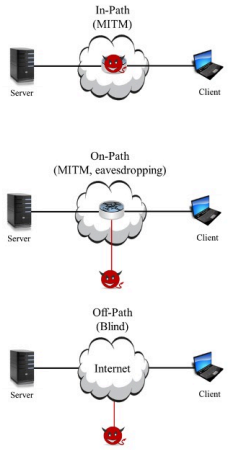
依据攻击者所处的不同位置，针对TCP的劫持攻击，通常有三种攻击模型：

- In-Path
- On-Path
- Off-Path



TCP劫持攻击

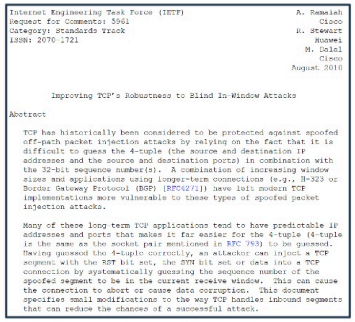
在前两种攻击模型中，攻击者能够嗅探到原始TCP连接的序列号，因此攻击难度不大。第三种Off-Path条件下的TCP劫持攻击，难度是最大的，也是当前TCP安全的一个研究热点



TCP劫持攻击

(1) 基于challenge ACK侧信道漏洞的TCP连接劫持

Challenge ACK是RFC5961里面定义的一种安全机制，用于提高TCP协议的安全性



Internet Engineering Task Force (IETF) — A. Ramaiah, Cisco
Request for Comments: 5961 — R. Stewart, Huawei
Category: Standards Track — M. Dalal, Cisco
ISSN: 2070-1721 — August 2010

Improving TCP's Robustness to Blind In-Window Attacks

Abstract

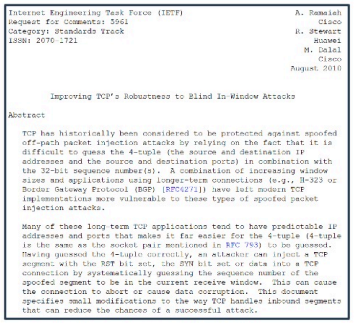
TCP has historically been considered to be protected against spoofed off-path packet injection attacks by relying on the fact that it is difficult to guess the 4-tuple (the source and destination IP addresses and the source and destination ports) in combination with the 32-bit sequence number(s). A combination of increasing window sizes and applications using longer-term connections (e.g., BGP Border Gateway Protocol (BGP) [RFC4271]) have left modern TCP implementations more vulnerable to these types of spoofed packet injection attacks.

Many of these long-term TCP applications tend to have predictable IP addresses and ports that makes it far easier for the 4-tuple (4-tuple is the same as the socket pair mentioned in RFC 793) to be guessed. Having guessed the 4-tuple correctly, an attacker can inject a TCP segment with the RST bit set, the SYN bit set or data into a TCP connection by systematically guessing the sequence number of the spoofed segment to be in the current receive window. This can cause the connection to abort or cause data corruption. This document specifies small modifications to the way TCP handles inbound segments that can reduce the chances of a successful attack.

TCP劫持攻击

（1）基于challenge ACK侧信道漏洞的TCP连接劫持

但该机制在实现时，为了提升性能，定义了一个全局的计数器，用于限制challenge ACK（挑战报文）的发送速率，而这个全局计数器，成为了一个侧信道漏洞



Internet Engineering Task Force (IETF) — A. Ramaiah, Cisco
Request for Comments: 5961 — R. Stewart, Huawei
Category: Standards Track — M. Dalal, Cisco
ISSN: 2070-1721 — August 2010

Improving TCP's Robustness to Blind In-Window Attacks

Abstract

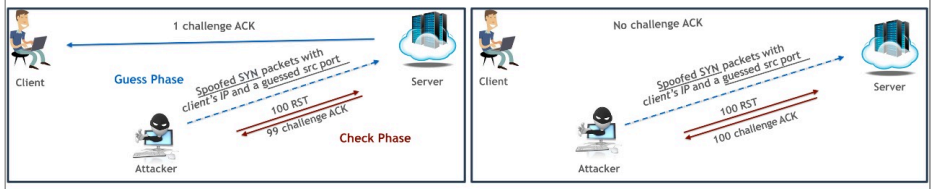
TCP has historically been considered to be protected against spoofed off-path packet injection attacks by relying on the fact that it is difficult to guess the 4-tuple (the source and destination IP addresses and the source and destination ports) in combination with the 32-bit sequence number(s). A combination of increasing window sizes and applications using long-term connections (e.g., BGP-4 or Border Gateway Protocol (BGP) [RFC4271]) have left modern TCP implementations more vulnerable to these types of spoofed packet injection attacks.

Many of these long-term TCP applications tend to have predictable IP addresses and ports that makes it far easier for the 4-tuple (4-tuple is the same as the socket pair mentioned in RFC 793) to be guessed. Having guessed the 4-tuple correctly, an attacker can inject a TCP segment with the RST bit set, the SYN bit set or data into a TCP connection by systematically guessing the sequence number of the spoofed segment to be in the current receive window. This can cause the connection to abort or cause data corruption. This document specifies small modifications to the way TCP handles inbound segments that can reduce the chances of a successful attack.

TCP劫持攻击

（1）基于challenge ACK侧信道漏洞的TCP连接劫持

一个旁路的攻击者，可以通过观测该侧信道漏洞，猜测出TCP连接的三个主要参数，即源端口号、序列号、确认号，进而构造伪造报文，劫持目标TCP连接



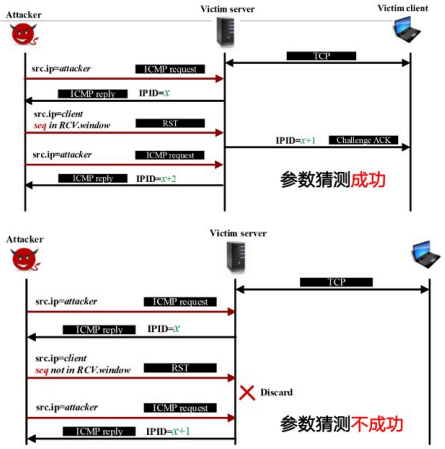
参数猜测成功　　参数猜测不成功

Cao Y, Qian Z, Wang Z, et al. Off-Path TCP Exploits: Global Rate Limit Considered Dangerous[C]. 25th USENIX Security Symposium. 2016.

TCP劫持攻击

（2）基于IPID侧信道漏洞的TCP连接劫持

在高版本的Linux内核中，系统采用了2种IPID分配策略。攻击者可以伪装成一个中间路由器，发送一个伪造的ICMP消息，操控受害主机的IPID分配方式，构建侧信道

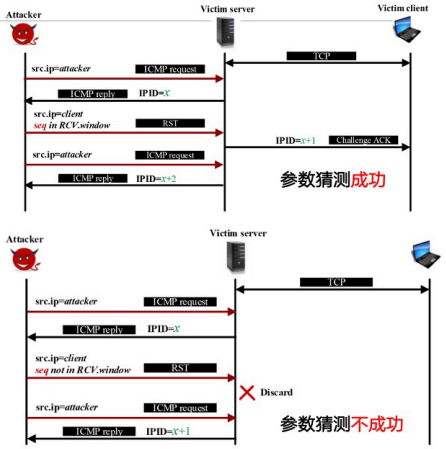


X. Feng, C. Fu, Q. Li, K. Sun, and K. Xu, "Off-path tcp exploits of the mixed ipid assignment," CCS'20

TCP劫持攻击

（2）基于IPID侧信道漏洞的TCP连接劫持

一旦IPID侧信道构建成功后，攻击者就可以通过观测该侧信道，推理猜测目标TCP连接的状态信息，最终实现对目标连接的劫持



X. Feng, C. Fu, Q. Li, K. Sun, and K. Xu, "Off-path tcp exploits of the mixed ipid assignment," CCS'20

TLS协议

传输层安全性协议（Transport Layer Security, TLS）及其前身安全套接层协议（Secure Sockets Layer, SSL）是一种广泛采用的安全性协议，旨在促进 Internet 上通信的隐私和数据安全性

Netscape

成立	1994年4月4日
结束	2003年7月15日
代表人物	马克·安德森、吉姆·克拉克、James L. Barksdale、Michael Homer、本·霍罗威茨

发明了：

HTTP cookie	JavaScript
SSL	jar

Mozilla基金会：

Firefox	ThunderBird

TLS协议

- 1994年，NetScape公司设计了SSL协议（Secure Sockets Layer）的1.0版，但是未发布。
- 1995年，NetScape公司发布SSL 2.0版，很快发现有严重漏洞。
- 1996年，SSL 3.0版问世，得到大规模应用。
- 1999年，互联网标准化组织ISOC接替NetScape公司，发布了SSL的升级版TLS1.0版。
- 2006年和2008年，TLS进行了两次升级，分别为TLS 1.1版和TLS 1.2版。
- 2011年，TLS 1.2修订版发布。
- 2018年，TLS 1.3发布。

协议设计

挑战：

1. 如何选择相同的算法、参数？
2. 如何产生和分发密钥？
3. 如何协同工作？
   - 不加密→加密的转换
   - 问题报告
4. 如何传输数据？
5. 如何感知对方存在(有会话)？

→ **握手协议（handshake）**
↓ **(密钥分配协议)**

→ **更改密码规范协议**

→ **警告协议**

→ **记录协议**

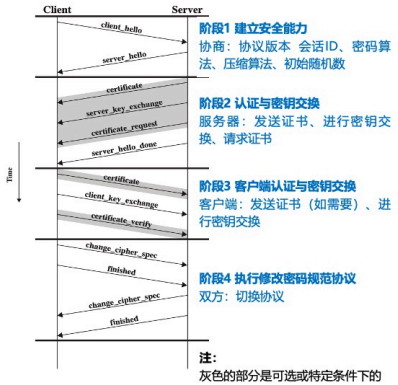
→ **心跳协议**

握手协议

用于

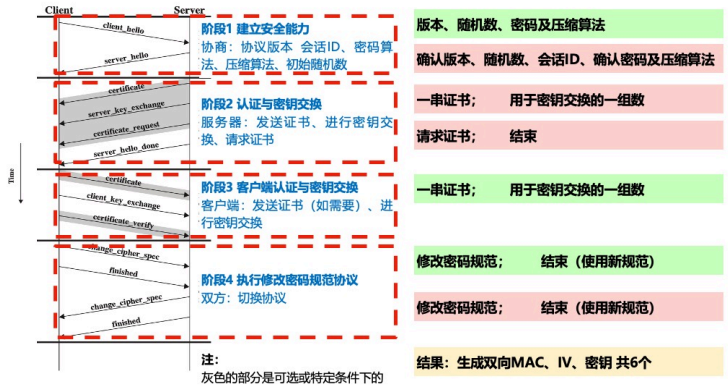
- 进行互相认证
- 协商算法参数
- 启动其他协议

四阶段消息交换



注：
灰色的部分是可选或特定条件下的

四阶段消息交换



版本、随机数、密码及压缩算法	
确认版本、随机数、会话ID、确认密码及压缩算法	
一串证书；	用于密钥交换的一组数
请求证书；	结束
一串证书；	用于密钥交换的一组数
修改密码规范；	结束（使用新规范）
修改密码规范；	结束（使用新规范）
结果：生成双向MAC、IV、密钥 共6个	

握手协议的安全性

握手协议基本使用明文

安全机制

- finished包中：
  - $PRF\ (master_secret, finish_label, HASH\ (handshake_messsages))$
- 可以发现内容篡改

修改密码规范协议（change cipher spec protocol）

- 使用记录协议通信
- 仅包含1字节：payload=1
- 将挂起状态改变为当前状态（原子操作）
- 更新密码算法组

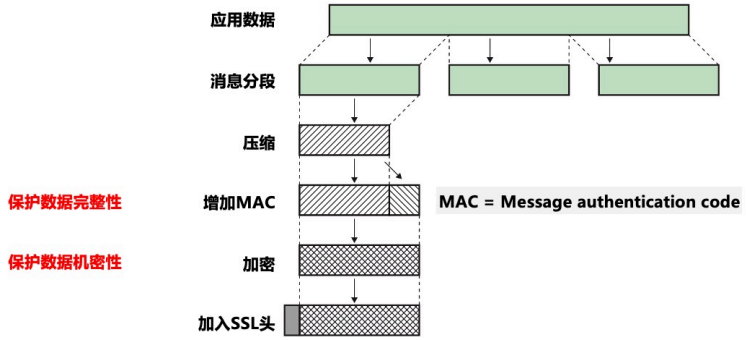
TLS会话与TCP连接

TLS会话

1. 使用握手协议建立TLS会话
2. 建立在TCP连接之上
3. 可以重用于多次连接
4. 客户端-服务器之间的单向关联
5. 规定了密码相关的参数

雨课堂 Rain Classroom

记录协议（record protocol）



137

安全性问题

1.身份的安全

2.算法与协议的安全

138

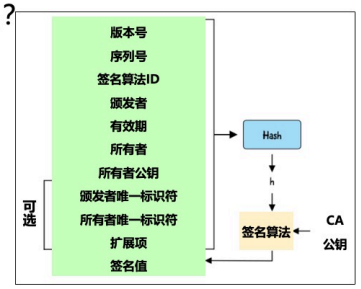
鉴别服务器身份

朴素的想法：

- amazon.com Inc发布公钥并签署其所有网站，以此类推
- 问题：公钥分发的公信力怎么解决？

成熟的方法：

- 请知名**证书机构(CA)**签发公钥
  - 有多知名？
- 浏览器怎么判断CA的的身份？
- 证书格式：ITU X.509(ISO 9594-8)



139

鉴别用户

多种方法：

- 证书
  1. 与服务器鉴别相同的方法
  2. 机构内部的CA与证书
  3. 手工生成并部署（例：github, git clone private repo）
- IP地址或口令
  - 不安全
  - cookie（导致用户信息安全问题）

140

雨课堂 Rain Classroom

信任是安全的基石

Blocking Trust for WoSign CA Free SSL Certificate G2

Update - April 1: As a result of a joint investigation of the events surrounding this incident by Google and CNNIC, we have decided that the CNNIC Root and EV CAs will no longer be recognized in Google products. This will take effect in a future Chrome update. To assist customers affected by this decision, for a limited time we will allow CNNIC's existing certificates to continue to be marked as trusted in Chrome, through the use of a publicly disclosed whitelist. While neither we nor CNNIC believe any further unauthorized digital certificates have been issued, nor do we believe the misissued certificates were used outside the limited scope of MCS Holdings' test network, CNNIC will be working to prevent any future incidents. CNNIC will implement Certificate Transparency for all of their certificates prior to any request for reinclusion. We applaud CNNIC on their proactive steps, and welcome them to reapply once suitable technical and procedural controls are in place.

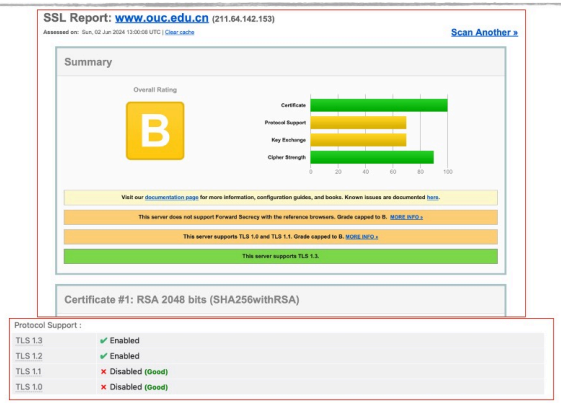
算法与协议的安全

Version	Additional Monitoring	Traffic Response	Asset Response
SSL 2.0	N/A	Immediate block	Disable service until reconfigured to only support TLS 1.2 and TLS 1.3.

Cipher Suite	Additional Monitoring	Traffic Response	Asset Response
NULL	N/A	Immediate block	Disable or quarantine until reconfigured.
RC2	N/A	Immediate block	Disable or quarantine until reconfigured.

Key Exchange Method	Additional Monitoring	Traffic Response	Server Response	Client Response
ANON	N/A	Immediate block	Disable or quarantine until reconfigured.	Disable or quarantine until reconfigured.
EXPORT	N/A	Immediate block	Disable or quarantine until reconfigured.	Disable or quarantine until reconfigured.
RSA with keys < 1024 bits (common sizes 512, 768)	N/A	Immediate block	Disable or quarantine until reconfigured. Install enterprise approved certificate.	Review configuration to ensure it is up to date. Reconfigure as necessary.
DHE with keys < 1024 bits (common sizes 512, 768)	N/A	Immediate block	Disable or quarantine until reconfigured.	Review configuration to ensure it is up to date. Reconfigure as necessary.
ECDHE with custom curves	N/A	Immediate block	Disable or quarantine until reconfigured.	Reconfigure to only offer recommended curves.
RSA with keys between 1024 and 2048 bits (common sizes 1024, 1536)	N/A	Detect/Block[13]	Reconfigure or update to support 3072 bit RSA, DHE with 3072 bits, and/or ECDHE with p384. Install enterprise	Reconfigure or update to support 3072 bit RSA, DHE with 3072 bits, and/or ECDHE with p384.

服务器/浏览器的安全设置



警告协议（Alert Protocol）

发送安全警告信息

- 字节1：
  - 1表示普通警告
  - 2表示致命警告（立即停止）
- 字节2：
  - 警告代码

心跳协议（Heartbeat Protocol）

定期发送，表明协议实体的可用性，2012年在 RFC 6250中增加。
在握手协议中，协商是否使用（支持）

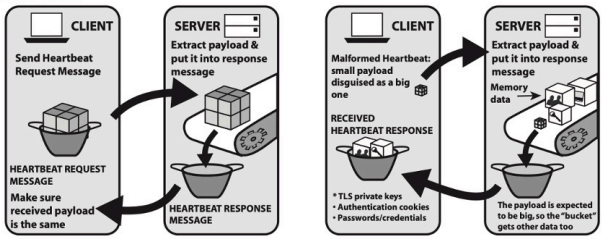
功能:

- 确认存活性
- 在连接空闲时产生消息活动

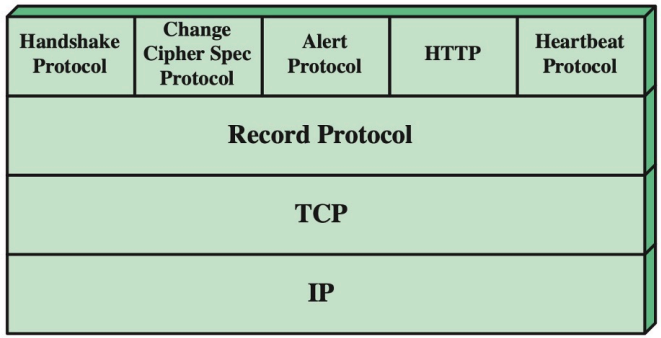
心脏滴血(Heartbleed)攻击

心脏滴血（openssl：CVE-2014-0160）

- 回复包使用memcpy复制请求包中长度为"payload"的payload

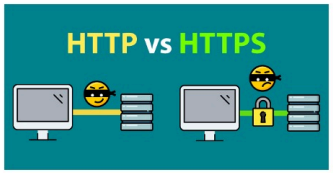


TLS 协议组成



TLS协议

广泛应用：
TLS是目前采用最广泛的一种安全性协议，应用于多个网络场景，如：对Web 应用程序和服务器之间的通信进行加密保护，还可用于电子邮件、消息传递和 IP 语音（VoIP）加密等



密码协议：认证

简单的鉴别协议（对称）

- 前提：P、Q存在长期有效的共享密钥k
- 存在重放攻击

$$
\begin{array}{lll}
P & : & \text{create } m = \text{“I am } P.\text{”} \\
 & : & \text{compute } m' = \{m, Q\}_k \\
P \rightarrow Q & : & m, m' \\
Q & : & \text{verify } \{m, Q\}_k \stackrel{?}{=} m' \\
 & : & \text{if equal then accept; otherwise reject}
\end{array}
$$

149

改进后的鉴别协议（对称）

必须有提前共享的密钥，可扩展性差，不能灵活增加主体

没有第三方，存在密钥爆炸问题

$$
\begin{array}{lll}
P \rightarrow Q & : & \text{“I am } P.\text{”} \\
 & : & \text{generate nonce } n \\
Q \rightarrow P & : & n \\
P & : & \text{compute } m = \{P, Q, n\}_k \\
P \rightarrow Q & : & m \\
Q & : & \text{verify } \{P, Q, n\}_k \stackrel{?}{=} m \\
 & : & \text{if equal then accept; otherwise reject}
\end{array}
$$

150

Woo–Lam协议-文献

Woo-Lam协议

- 论文：
  - Thomas Y.C. Woo, Simon S. Lam, "Authentication for Distributed Systems", Computer, vol. 25, no. , pp. 39-52, January 1992, doi:10.1109/2.108052
- 作者自己的修正：
  - S.S. Lam, T.Y.C. Woo, "Authentication Revisited", Computer, vol. 25, no. , pp. 10, March 1992, doi:10.1109/2.121502
- 维基：https://en.wikipedia.org/wiki/Woo–Lam

151

鉴别分类-From woo-lam

from：K. Shankar. The total computer security problem. Computer, 10(6):50–73, June 1977.

Approaches to authentication

All authentication procedures involve checking known information about a claimed identity against information supplied by the claimant during the identity verification procedure. Such checking can be based on the following three approaches [2].

Proof by Knowledge. The claimant demonstrates knowledge of some information regarding the claimed identity that can only be known or produced by a principal with the claimed identity. For example, password knowledge is used in most login procedures. A proof by knowledge can be conducted by a direct demonstration, like typing in a password, or by an indirect demonstration, such as correctly computing replies to challenges by a verifier. Direct demonstration is not preferable from a security viewpoint, since a compromised verifier can record the submitted knowledge and later impersonate the claimant by presenting the recorded knowledge. Indirect demonstration can be designed to induce high confidence in the verifier, without leaving any clue to how the claimant's replies are computed. For example, Feige, Fiat, and Shamir proposed a *zero-knowledge* protocol for proof of identity [1]. This protocol allows a claimant C to prove to a verifier V that C knows how to compute replies to challenges posed by V without revealing what the replies are. These protocols are provably secure (under complexity assumptions). However, additional refinements are needed before they can be applied in practical systems.

Proof by Possession. The claimant produces an item that can only be possessed by a principal with the claimed identity, for example, an ID badge. For this to work, the item has to be unforgeable and safely guarded.

Proof by Property. The verifier directly measures certain claimant properties. For example, various biometric techniques can be used: fingerprint, retina print, and so on. The measured property has to be distinguishing, that is, unique among all possible principals.

Proof by knowledge and possession (and combinations thereof) can be applied to all types of authentication needs in a secure distributed system, while proof by property is generally limited to the authentication of human users by a host equipped with specialized measuring instruments.

152

雨课堂 Rain Classroom

基本的鉴别协议-From woo-lam

基于口令的鉴别协议，直接提供口令给验证方

实现与改进

- f可以是Hash函数
- 参数可以增加Salt
- f的计算可以放在被验证方

$$
\begin{array}{lcl}
U \rightarrow H & : & U \\
H \rightarrow U & : & \text{“Please enter password”} \\
U \rightarrow H & : & p \\
H & : & \text{compute } y = f(p) \\
 & : & \text{retrieve user record } (U, f(password_U)) \text{ from user database} \\
 & : & \text{if } y = f(password_U) \text{ then accept; otherwise reject}
\end{array}
$$

153

一种弱Woo-lam协议

存在并行会话攻击

A返回给Q的消息，Q不能区分与之相关的通信者P

$$
\begin{array}{lcl}
P \rightarrow Q & : & \text{“I am } P\text{.”} \\
Q & : & \text{generate nonce } n \\
Q \rightarrow P & : & n \\
P & : & \text{compute } x = \{P, Q, n\}_{k_{PA}} \\
P \rightarrow Q & : & x \\
Q & : & \text{compute } y = \{P, Q, x\}_{k_{QA}} \\
Q \rightarrow A & : & y \\
A & : & \text{recover } P, Q, x \text{ from } y \text{ by decrypting with } k_{QA} \\
 & : & \text{recover } P, Q, n \text{ from } x \text{ by decrypting with } k_{PA} \\
 & : & \text{compute } m = \{P, Q, n\}_{k_{QA}} \\
A \rightarrow Q & : & m \\
Q & : & \text{verify } \{P, Q, n\}_{k_{QA}} \stackrel{?}{=} m \\
 & : & \text{if equal then accept; otherwise reject}
\end{array}
$$

154

Woo–Lam协议-对称

Q不验证x，

- 如果P将另一会话中的n'当成x送给Q，Q也会直接加密送去给A，这时候截获，重放给Q，就会当成另一会话的验证通过的消息。
- 甚至直接把n当成x返回给Q，截获Q发给A的消息，再重放给Q即可。【反射攻击】

$$
\begin{array}{lcl}
P \rightarrow Q & : & \text{“I am } P\text{.”} \\
Q & : & \text{generate nonce } n \\
Q \rightarrow P & : & n \\
P & : & \text{compute } x = \{P, Q, n\}_{k_{PA}} \\
P \rightarrow Q & : & x \\
Q & : & \text{compute } y = \{P, Q, x\}_{k_{QA}} \\
Q \rightarrow A & : & y \\
A & : & \text{recover } P, Q, x \text{ from } y \text{ by decrypting with } k_{QA} \\
 & : & \text{recover } P, Q, n \text{ from } x \text{ by decrypting with } k_{PA} \\
 & : & \text{compute } m = \{P, Q, n\}_{k_{QA}} \\
A \rightarrow Q & : & m \\
Q & : & \text{verify } \{P, Q, n\}_{k_{QA}} \stackrel{?}{=} m \\
 & : & \text{if equal then accept; otherwise reject}
\end{array}
$$

155

Woo–Lam协议-非对称

$$
\begin{array}{lcl}
P \rightarrow Q & : & \text{“I am } P\text{.”} \\
Q & : & \text{generate nonce } n \\
Q \rightarrow P & : & n \\
P & : & \text{compute } m = \{P, Q, n\}_{k_P^{-1}} \\
P \rightarrow Q & : & m \\
Q \rightarrow A & : & \text{“I need } P\text{'s public key.”} \\
A & : & \text{retrieve public key } k_P \text{ of } P \text{ from key database} \\
 & : & \text{create certificate } c = \{P, k_P\}_{k_A^{-1}} \\
A \rightarrow Q & : & P, c \\
Q & : & \text{recover } (P, k_P) \text{ from } c \text{ by decrypting with } k_A \\
 & : & \text{verify } (P, Q, n) \stackrel{?}{=} \{m\}_{k_P} \\
 & : & \text{if equal then accept; otherwise reject}
\end{array}
$$

156

雨课堂 Rain Classroom

协议分析

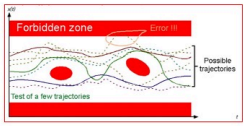
安全协议（密码协议）能否达成目标？如何分析？

- 这是技艺（Art），还是科学？
  - 如果靠经验、洞察力、尝试 → 手工方法 + 数学
  - 如果使用数学/逻辑/自动方法 → 形式化/AI/自动 + 手工
    - 对形式化分析有兴趣，自学BAN、PCL等
      - 基于逻辑

157

测试/模糊测试

测试：最直接的方式



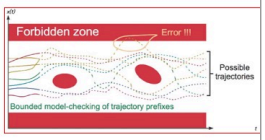
- 尽可能穷举交互序列，看有无安全问题
- 优点：便于实施，易理解，误报少
- 缺点：穷举无法考虑到所有情况，漏报多
- 挑战：
  - 如何产生有价值的输入？如何判断异常发生？如何确定异常的根因？
- 技巧：
  - 通过划分等价类的方式，满足覆盖率，使无穷变有穷
  - 通过自动分析协议软件的代码，为自动化测试生成有价值的输入序列
  - ……

158

(有界)模型检测

模型检验：穷举有限步骤的所有序列

- 案例：
  - Lowe使用CSP对协议进行编码，使用模型检测工具FDR进行分析，发现Needham-Schroeder的中间人攻击漏洞
  - 该协议之前被证明为安全的（什么启示？）
- 步骤
  - 建模：{通信者+攻击者} · 并发 · 异步
  - 规约：
    - 机密性属性：“攻击者永远无法获知会话密钥”
    - 认证属性：“A确信它正在与B通信”
  - 验证与输出



159

证明

证明：信念的传递

- 初始信念 → 逻辑推理 → 可证明的结论（BAN逻辑）
  - 初始信念（类似几何证明的已知条件或假设）：
    - P(张三进程) Believe X
    - P sees（收到过） X
    - P saids（发送过）X
    - fresh(X) 或 #(X)：X新鲜的
    - $\{X\}_k$：用k对X加密
    - P controls X：P对X（通常是密钥）有管辖权

$P \overset{k}{\leftrightarrow} Q$ k为P和Q的共享密钥，其他人不知道

$\overset{k}{\rightarrow} Q$ k为Q的公钥，其他人不知道对应私钥

$P \overset{x}{\rightleftarrows} Q$ x为P和Q的共享秘密

160

证明

证明：信念的传递

建立"信念同步"

- 初始信念 → 逻辑推理 → 可证明的结论（BAN逻辑）
  - 逻辑推理规则

R1: 消息含义规则

$$\frac{P \text{ believes } (Q \leftrightarrow P),\ P \text{ sees } \{X\}_k}{P \text{ believes } (Q \text{ said } X)}$$

R3: 管辖规则

$$\frac{P \text{ believes } (Q \text{ controls } X),\ P \text{ believes } (Q \text{ believes } X)}{P \text{ believes } X}$$

R2: 临时值验证规则

$$\frac{P \text{ believes fresh}(X),\ P \text{ believes } (Q \text{ said } X)}{P \text{ believes } (Q \text{ believes } X)}$$

R4: 看见规则的分解

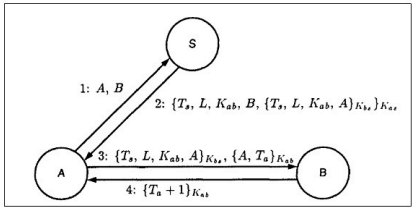
$$\frac{P \text{ sees } (X, Y)}{P \text{ sees } X}$$

R5: 新鲜性规则的分解

$$\frac{P \text{ believes fresh}(X)}{P \text{ believes fresh}(X, Y)}$$

证明Kerberos协议举例

1. 协议描述



Message 1. $A \rightarrow S: A, B.$
Message 2. $S \rightarrow A: \{T_s, L, K_{ab}, B, \{T_s, L, K_{ab}, A\}_{K_{bs}}\}_{K_{as}}.$
Message 3. $A \rightarrow B: \{T_s, L, K_{ab}, A\}_{K_{bs}}, \{A, T_a\}_{K_{ab}}.$
Message 4. $B \rightarrow A: \{T_a + 1\}_{K_{ab}}.$

说明
1. S是认证服务器，与A、B均有共享密钥
2. 前三步完成单向认证
3. 第四步的目的是双向认证
4. T：timestamp
   L：lifetime

证明Kerberos协议举例

2. 协议理想化

Message 2. $S \rightarrow A: \{T_s, A \overset{K_{ab}}{\leftrightarrow} B, \{T_s, A \overset{K_{ab}}{\leftrightarrow} B\}_{K_{bs}}\}_{K_{as}}.$
Message 3. $A \rightarrow B: \{T_s, A \overset{K_{ab}}{\leftrightarrow} B\}_{K_{bs}}, \{T_a, A \overset{K_{ab}}{\leftrightarrow} B\}_{K_{ab}}$ *from A.*
Message 4. $B \rightarrow A: \{T_a, A \overset{K_{ab}}{\leftrightarrow} B\}_{K_{ab}}$ *from B.*

1. T与L进行合并（简化nonce）
2. 忽略消息1（没有贡献）
3. Kab替换为AB拥有共享密钥（理解协议得出）

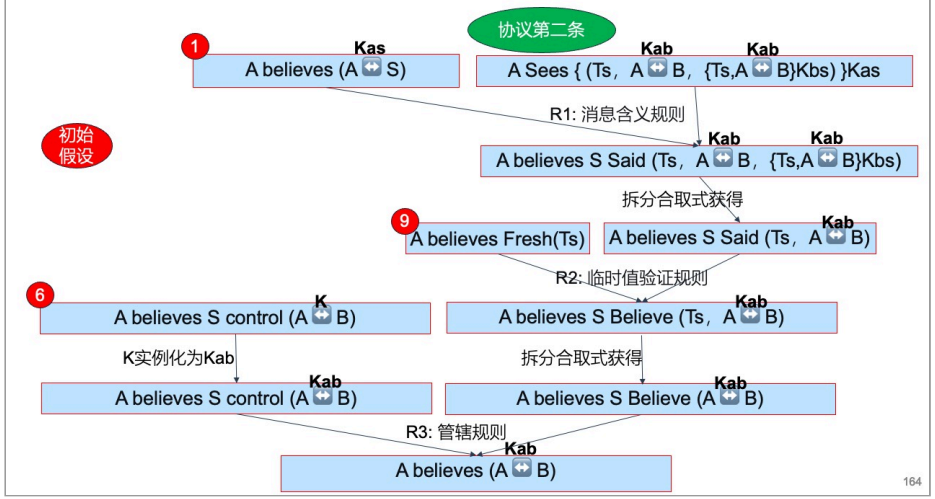
3.初始假设

A believes $A \overset{K_{as}}{\leftrightarrow} S$,	B believes $B \overset{K_{bs}}{\leftrightarrow} S$,
S believes $A \overset{K_{as}}{\leftrightarrow} S$,	S believes $B \overset{K_{bs}}{\leftrightarrow} S$,
S believes $A \overset{K_{ab}}{\leftrightarrow} B$,	B believes (S controls $A \overset{K_{ab}}{\leftrightarrow} B$),
A believes (S controls $A \overset{K_{ab}}{\leftrightarrow} B$),	B believes fresh(T_s),
A believes fresh(T_s),	B believes fresh(T_a).

1. 前4条是协议原有的假设
2. 第5条是S产生了密钥
3. 第6、7条说明A、B信任S能力
4. 最后3条说明时间戳的新鲜性

4.最终目标

A believes $A \overset{K_{ab}}{\leftrightarrow} B$	B believes $A \overset{K_{ab}}{\leftrightarrow} B$
A believes B believes $A \overset{K_{ab}}{\leftrightarrow} B$	B believes A believes $A \overset{K_{ab}}{\leftrightarrow} B$



通过第三条消息，类似以上推理得出：

Kab
B believes (A ↔ B)

通过第三条消息的Kab加密内容，得出：

Kab
B believes A believes (A ↔ B)

通过第四条消息，得出：

Kab
A believes B believes (A ↔ B)

165

证明

证明：信念的传递

- 初始信念 → 逻辑推理 → 可证明的结论（BAN逻辑）
  - BAN逻辑由Burrows、Abadi和Needham在1989年提出的，是安全协议形式化分析领域的一座里程碑
    - Burrows M, Abad M, Needham R M. A Logic of Authentication[J]. Proceedings of the Royal Society of London. Series A, Mathematical and Physical Sciences, 1989: 233-271.
    - Burrows M, Abadi M, Needham R. A logic of authentication[C]//Proceedings of the twelfth ACM symposium on Operating systems principles. 1989: 1-13.
    - Burrows M, Abadi M, Needham R. A logic of authentication[J]. ACM Transactions on Computer Systems (TOCS), 1990, 8(1): 18-36.
  - BAN逻辑不能证明协议绝对安全，而是检验协议一致性的强大助手
  - BAN逻辑之后，GNY、AT、VO、SVO等逻辑方法提出

这三篇文章是同一个内容吗？是不是一稿多投？

这三个条目**确实是同一项研究的不同"版本/阶段"**，但并不是完全意义上的"一稿多投"。这是学术出版中非常常见、合规、受认可的流程。下面给你一个清晰的解释：

一、三篇论文的关系（核心观点：同一研究的不同阶段）

引文	类型	年份	特点
1. Proceedings of the Royal Society A (1989)	期刊论文	1989	早期正式期刊发表，理论化、数学推导较强
2. SOSP 1989 (Conference Proceedings)	顶会论文	1989	面向系统研究社区，篇幅短、强调系统应用
3. ACM TOCS 1990	顶级期刊长文	1990	最全面的版本，扩展实验/论证/证明

总结：

这是同一个研究成果逐步扩展和升级的"三连发"：会议短文 → 初版期刊 → 扩展期刊。

尤其最后的 **TOCS 1990** 是最完整版本（一般在学术界引用最多）。

二、为什么这是合法的，不属于"一稿多投"？

因为这些投稿属于学术界非常明确允许的模式：

1. "会议扩展版（conference → journal extended version）"完全合法

在计算机科学（尤其操作系统、安全、网络等领域），顶会（如SOSP、OSDI、SIGCOMM）的论文通常篇幅有限，只能写核心贡献。

所以作者会在之后提交一个**扩展版 journal paper**（增加证明、实验、应用等），这种行为不仅允许，还很常见。

三篇中：

SOSP 1989 → TOCS 1990 是典型的会议扩展为期刊

期刊会明确要求：

- 内容需有**足够的新材料**（通常要求 ≥30%）
- 引用自己先前的会议论文
- 主张"不是重复投稿"，而是"扩展版"

这完全符合当时 ACM/IEEE 的规则。

2. Proceedings of the Royal Society A (1989) 的版本

这篇比较特别，它属于更数学化的期刊，风格偏形式逻辑与数学推导。

当时跨社区交叉投稿是被接受的（计算机系统 vs 数[illegible]辑的 community），内容也并非完全重复，而是偏理论、形式化逻辑推导。

雨课堂 Rain Classroom

网络协议安全 → 网络安全协议

- 网络协议
- 网络协议的安全
- 网络安全协议
- 网络安全协议的安全
- ……

总结

169